cloudmed™

Report on Cloudmed's Description of the Cloudmed Revenue Intelligence System and the Suitability of the Design and Operating Effectiveness of Controls for the Period of November 1, 2019 through October 31, 2020 Relating to Security

SOC 2®

IS Partners
Audits Without Anxiety®

This report is not to be copied or reproduced in any manner without the expressed written approval of Cloudmed. The report, including the title page, table of contents, and exhibits, constitutes the entire report and should be referred to only in its entirety and not by its component parts. The report contains proprietary information and is considered confidential.

cloudmed™

TABLE OF CONTENTS

I.	**INDEPENDENT SERVICE AUDITOR'S REPORT**	
II.	**CLOUDMED'S MANAGEMENT ASSERTION**	
III.	**CLOUDMED'S DESCRIPTION OF THE REVENUE INTELLIGENCE SYSTEM**	9
IV.	**OTHER RELEVANT ASPECTS OF THE CONTROL ENVIRONMENT, RISK ASSESSMENT PROCESS, INFORMATION AND COMMUNICATION SYSTEMS, AND MONITORING CONTROLS**	21
V.	**SUBSERVICE ORGANIZATIONS**	39
VI.	**COMPLEMENTARY USER ENTITY CONTROLS**	42
VII.	**INDEPENDENT SERVICE AUDITOR'S DESCRIPTION OF TESTS OF CONTROLS AND RESULTS**	43
VIII.	**ADDITIONAL INFORMATION PROVIDED BY THE INDEPENDENT SERVICE AUDITOR**	83

I. INDEPENDENT SERVICE AUDITOR'S REPORT

To the Management of Cloudmed:

Scope
We have examined Cloudmed's ("Cloudmed") accompanying description of the Revenue Intelligence system titled "Cloudmed's Description of the Revenue Intelligence System" (description) throughout the period November 1, 2019 through October 31, 2020, based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period November 1, 2019 through October 31, 2020, to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the trust services criteria relevant to security (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria).*

Cloudmed uses a subservice organization to provide infrastructure hosting cloud services in support of the Revenue Intelligence system. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents Cloudmed's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Cloudmed's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents Cloudmed's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Cloudmed's controls. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such controls.

Service organization's responsibilities
Cloudmed is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved. Cloudmed has provided the accompanying assertion titled "Cloudmed's

Management Assertion" (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. Cloudmed is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service auditor's responsibilities
Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of the description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent limitations
The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of tests of controls
The specific controls we tested, and the nature, timing and results of those tests are presented in section VII.

Opinion
In our opinion, in all material respects,

a. The description presents Cloudmed's Revenue Intelligence system that was designed and implemented throughout the period November 1, 2019 through October 31, 2020, in accordance with the description criteria.

b. The controls stated in the description were suitably designed throughout the period November 1, 2019 through October 31, 2020 to provide reasonable assurance that Cloudmed's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if subservice organizations and user entities applied the complementary controls assumed in the design of Cloudmed's controls throughout that period.

c. The controls stated in the description operated effectively throughout the period November 1, 2019 through October 31, 2020, to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of Cloudmed's controls operated effectively throughout that period.

Restricted use

This report, including the description of tests of controls and results thereof in section VII, is intended solely for the information and use of Cloudmed, user entities of Cloudmed's Revenue Intelligence system during some or all of the period November 1, 2019 through October 31, 2020, business partners of Cloudmed subject to risks arising from interactions with the Revenue Intelligence system, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties
- Internal control and its limitations
- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

IS Partners, LLC

IS Partners, LLC
Dresher, Pennsylvania
March 30, 2021

IS Partners, LLC
1668 Susquehanna Road
Dresher, PA 19025

215.675.1400 main office
215.259.7928 fax
ispartnersllc.com

II. CLOUDMED SOLUTIONS, LLC's MANAGEMENT ASSERTION

We have prepared the accompanying description of Cloudmed's ("Cloudmed") Revenue Intelligence system titled "Cloudmed's Description of the Revenue Intelligence System" ("description") throughout the period November 1, 2019 through October 31, 2020, based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) ("description criteria"). The description is intended to provide report users with information about the Revenue Intelligence system that may be useful when assessing the risks arising from interactions with Cloudmed's system, particularly information about system controls that Cloudmed has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security ("applicable trust services criteria") set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

Cloudmed uses a subservice organization to provide certain services in support of its Revenue Intelligence system. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents Cloudmed's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Cloudmed's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents Cloudmed's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Cloudmed's controls.

We confirm, to the best of our knowledge and belief, that:

a. The description presents Cloudmed's Revenue Intelligence system that was designed and implemented throughout the period November 1, 2019 through October 31, 2020, in accordance with the description criteria.

b. The controls stated in the description were suitably designed throughout the period November 1, 2019 through October 31, 2020 to provide reasonable assurance that Cloudmed's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if subservice organizations and user entities applied the complementary controls assumed in the design of Cloudmed's controls throughout

that period.

c. The controls stated in the description operated effectively throughout the period November 1, 2019 through October 31, 2020, to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and user entity controls assumed in the design of Cloudmed's controls operated effectively throughout that period.

III. CLOUDMED'S DESCRIPTION OF THE REVENUE INTELLIGENCE SYSTEM

Background

Cloudmed is a first-of-its-kind, single-source enterprise platform provider of Revenue Intelligence solutions for hospitals. Cloudmed's approach of combining human expertise with advanced technology utilizing machine learning algorithms provides a smarter, more predictive way for clients to realize all potential revenue. Today, Cloudmed partners with over 3,100 healthcare providers in the United States and recovers over $1.2 billion of underpaid or unidentified revenue for its clients annually. Cloudmed (Triage solution) is the 2020 Revenue Integrity and Underpayment Services KLAS Category Leader and its solution suites have HFMA Peer Review status and are HITRUST certified (www.cloudmed.com).

Charge Capture

Cloudmed's industry-leading technology identifies missed, misplaced and miscoded charges and aligns physician and hospital billing functions across inpatient, outpatient, primary care and specialty settings. Cloudmed helps identify additional revenue for its clients with a continual focus on recognizing how when, and where missed or inaccurate coding, charging and documentation occurs. The Charge Capture technology creates a unique patient identifier to link all hospital and physician visits for an episode of care and identify missed revenue opportunities across that entire episode. Innovative technologies and processes identify and categorize additional revenue opportunities where missed or inaccurate coding, charging and documentation occurs. Cloudmed auditors analyze coding, CDI and documentation during review of patient medical records. A comprehensive rules library is applied at various levels of the payer contracts and coverage profile. A true chart-to-claim audit is conducted by coupling technology with expert reviewers to identify revenue opportunities. Client-specific charge capture policies and procedures are reviewed to ensure rule sets are customized for each client.

DRG Validation

Cloudmed's powerful automated DRG Validation solution is the first of its kind to combine both technology and hands-on auditing. It is a web-based, fully HIPAA-compliant solution utilizes rules-based algorithms that target potential coding anomalies and/or documentation improvement opportunities at the time of coding completion. The DRG Validation solution is backed by Cloudmed's experienced auditing staff who provide supporting documentation from the client's medical records, along with industry-recognized references (coding conventions / guidelines, AHA Coding Clinic advice, etc.) to support the recommendations for DRG revision. The final decision on the DRG shift is always made by the client. Cloudmed's intuitive interface allows staff to easily review recommendations and quickly make decisions. The DRG Validation solution also serves as an educational tool to increase CMI, accuracy, compliance, and quality, through dashboards, reporting, and closed loop feedback.

Medicare Reimbursement Services

Cloudmed maximizes Medicare reimbursement on both a retrospective and prospective basis through their best-in-class Disproportionate Share Hospital ("DSH"), Worksheet S-10, 340B Discovery, and Medicare Bad Debt ("MBD") services. Also, Cloudmed supports most other areas of the Medicare cost report, including medical education and organ transplant reviews,

along with full preparation and comprehensive reviews. The proprietary software solution, COMPASS, uses advanced data algorithms and intelligent queries to effortlessly find eligibility matches that other firms cannot.

Transfer DRG

Supported by Cloudmed's next-generation Revenue Assurance platform, the Transfer DRG results consistently recover up to 70% more than the competition and up to 120% more than providers who have completed similar reviews internally. Cloudmed couples an industry-leading Revenue Intelligence system with hands-on regulatory and clinical expertise. Cloudmed's two-step approach identifies all uncovered revenue which cannot be accomplished through technology processing alone. Cloudmed contacts Medicare Administrative Contractors (MAC) to validate findings prior to submitting claims for re-processing.

Underpayment

Within Cloudmed's Payer Accountability Suite, Cloudmed provides Underpayment Review services of managed care and governmental payer-focused zero-balance accounts in a retrospective manner, seeking to recover underpaid and denied dollars services. Cloudmed offers a customizable offering of Underpayment Recovery solutions and prospective claims support in a safety-net manner. Cloudmed's Underpayment turn-key solution requires limited resources from clients. Highly trained clinical nurses perform comprehensive audits and medical record reviews in order to determine how to best appeal and collect clinically disputed underpaid claims. Cloudmed ensures appropriate reimbursement calculations across multiple payors. CDM experts conduct targeted audits to identify missing or misbilled charges. All the services provided within the Underpayment platform help provide an unrivaled ability to tailor pricing for facility-specific reimbursement structures.

Denials

Hospitals turn to Cloudmed for support of active Denials Management resolution and mitigation. Cloudmed's solution decreases denial inventory by up to 20% with a customized optimization plan actively managed by our skilled clinicians, attorneys, and reimbursement specialists.

Cloudmed resolves medical claims that medical insurance carriers, governmental payers, managed care organizations, or any other payers have either underpaid or failed to pay. Clients select and refer to Cloudmed any claim with a variance between the amount owed and the amount paid, even if the variance is not labeled as a "denial." The types of claims suitable for referral include, but are not limited to, the following:

- any Claim which a Payer has **denied, in whole or in part**, either verbally or in writing; and
- any Claim which a Payer has **underpaid or paid and recouped**; and
- any Claim which a Payer has **been slow to pay**; and,
- any Claim that Trinity Health anticipates a Payer **will deny or recoup**.

Cloudmed's process after referral can include, when appropriate:

- Procurement of necessary documentation via remote electronic access to HIM and PFS systems for the recovery process
- Completing clinical and coding reviews when necessary to address denial
- Creation and sending of appeals to Payers
- Recovery follow-up with Payers (and their subcontractors)
- Confirmation of paid Claims after appeal overturn
- Detailed Claim level monthly reporting
- Rebill submission or request dependent on client protocols

Principal Service Commitments and System Requirements

Cloudmed designs its processes and procedures related to the Revenue Intelligence solution and the underlying system to meet its objectives for its "Revenue Intelligence Services." "Revenue Intelligence Services" shall mean data collection and storage, data processing and mapping, internal support activities like HIPAA privacy trainings and security, securing confidential and private information and other support services. Those objectives are based on the service commitments that Cloudmed makes to user entities, the laws and regulations that govern the provision of other healthcare industry services, and the financial, operational, and compliance requirements that Cloudmed has established for the services. The professional services of Cloudmed are subject to the Health Insurance Portability and Accountability Act (HIPAA), including relevant regulations, as well as state privacy security laws and regulations in the jurisdictions in which Cloudmed operates.

Commitments to user entities are documented and communicated in Statements of Service contracts, Non-Disclosure agreements, or other ordering documentation. These commitments are standardized and include, but are not limited to, the following:

- The permissible use and disclosure of Protected Health Information (PHI).
- Limitations and the reporting of disclosures of PHI.
- Access and Availability to PHI.
- Electronic PHI and Compliance with Security Rule.
- Compliance with Privacy Rule.
- Third Party Rights and Supplier Limitations.
- Changes in governing laws.

This description covers Cloudmed's Revenue Intelligence system (the "system").

Components of the System
The system is comprised of the following five components:

- Infrastructure (facilities, equipment, and networks)
- Software (systems, applications, and utilities)
- People (developers, operators, users, and managers)
- Procedures (automated and manual)
- Data (transactions streams, files, databases, and tables)

The following sections of this description define each of these five components comprising Cloudmed's system and other relevant aspects of Cloudmed's control environment, risk assessment process, information and communication systems, and monitoring controls.

Infrastructure and Software

Cloudmed has 4 office locations throughout the United States with approximately 1400+ number of employees. Cloudmed's headquarters was located in Plano, TX and has moved to Atlanta, GA.

- Cloudmed has a Revenue Intelligence platform built and supported in Azure that provides auditing tool for multiple service lines. A consolidated database system called Data Lake uses Couchbase, Azure, and some SQL to support the Revenue Intelligence platform. Microsoft O365, Intune, Azure AD, and Azure is utilized by Cloudmed's workforce for communication, password authentication, device management, and security controls.
- Atlanta, GA is the corporate office with offices for Executive Management and Plano, TX is the corporate office with offices for Finance department. The workforce uses O365 and Azure AD. There are also finance and accounting applications that are managed by vendor and not Cloudmed which are not part of the audit scope.

Primary Systems

Cloudmed primarily uses cloud-based Microsoft Azure environment with a mixture of Windows and Linux servers to support a Data Lake system and Revenue Intelligence platform, a web-hosted application that stores and process ePHI for the revenue recovery solutions. Microsoft O365 with E5 licensing provides O365 Exchange, Office Apps and various security and compliance tools such as Defender ATP (E5), Cloud App Security, DLP, O365 Security and O365 Compliance. Microsoft Teams provides an internal communications interface and an online meeting resource. SharePoint is used for information, resource sharing, and document sharing. The Azure environment includes Azure Security Center and Microsoft Sentinel for firewall and network protection and a centralized audit logging and monitoring console for capturing and analyzing logs from all areas of O365 and Azure and the Revenue Intelligence platform. Microsoft Intune enables Cloudmed to enforce device encryption and antimalware protections to all endpoints. Azure Security Center has several pieces of protections such as IDS/IPS functionality, Privileged Identity Management, and Network Security Groups. The Data Lake is composed of SQL servers, Couchbase, Azure Data Bricks, and Azure Data Factory. Vulnerability scanning is primarily completed with SAINT Security Suite though other scanners are used to supplement or validate results. Cloudmed Connect is main tool for receiving and sending files including data file transfers sent from clients to Cloudmed for contracted work.

Services Outsourced

Cloudmed is completely cloud hosted by Microsoft Azure environment, Microsoft O365 E5, and VMWare environments with ADAR IT and Virtacore. ADAR IT provides virtual desktops and servers within the ADAR IT datacenter with firewall and network protection and 24x7 support. Virtacore provides VMWare hosting of servers maintained by Cloudmed employees and hosting of virtual networks and firewalls with customer support as needed for

networks and firewalls. Both ADAR IT and Virtacore provide virtual infrastructure and related support. As needed, Cloudmed contracts with various for media destruction but does sanitization in-house. Professional shredding services are contracted for office locations that support printing. VoIP services are provided by Intermedia.

Scope Overview

Cloudmed utilizes secure cloud-based Azure datacenters in multiple U.S. based datacenters for its primary storage of servers, applications, and networking with secure O365 Exchange, Office applications and Defender ATP with E5 licensing for collaboration, electronic communication, and documentation development. Secure VMWare environments are used to host legacy, virtual desktops, servers, and applications pending transition to Azure environment.

System Name	Components	Service Offering
Revenue Intelligence Platform	• .NET • JAVA	• Revenue Recovery solutions
Microsoft Azure	• Virtual Servers • Virtual resources • Virtual database system • Web applications	• Cloud hosting
Microsoft Azure Security Center	• Network Security Groups • IDS/IPS	• Security
Microsoft O365 E5	• Exchange • Office Apps • SharePoint • Teams • O365 Security • O365 Compliance • O365 Cloud App Security • Defender ATP	• Communication (emails) • Office tools • Collaboration tools • Security tools • Compliance tools
Data Lake	• Couchbase • SQL Servers • Azure Data Bricks • Azure Data Factory	• Database system
VMWare	• Servers • Desktops • Networks • Firewalls	• Virtual resources
Microsoft Sentinel	• Central Repository for audit logs	• Review and analysis of audit logs and alerts

System Name	Components	Service Offering
SAINT Security Suite	• Vulnerability Scanner • Penetration Tester	• Vulnerability Scanning and Penetration testing
Revint Connect	• Cerberus FTP Server	• File transfer site with options for HTTPS over TLS 1.2 or SFTP protocols

- **Network Connections -** Cloudmed operates in Azure's encrypted cloud environment behind virtual firewalls with controlled traffic and connections made according to specific VLAN routing rules. Azure is a large, logical sub network that manages external-facing and internal-facing services for smaller logical subnetworks such as Cloudmed

  Cloudmed has public facing application sites hosted by private servers. The organization's security gateways enforce security policies and are configured to filter traffic between domains, block unauthorized access, and are used to maintain segregation between internal wired, internal wireless, and external network segments including DMZs and enforce access control policies for each of the domains.

  These standards are designed to minimize the potential exposure to Cloudmed from the loss of sensitive or company confidential data, intellectual property, damage to public image etc., which may follow from unauthorized use of Cloudmed resources. Devices that are internet facing and outside the Cloudmed firewall are considered part of the DMZ.

  All connections are restricted to the Azure Remote Gateway server, secure web protocols such as https. Cloudmed controls access to all servers and services by limiting external access with VPN tunnels, IP whitelists, and internal access with AD authentication and Group Policy controls. Revint Connect is SFTP and HTTPS compatible. Whitelisting can be done but is not restricted to only whitelisting. Each person and site has unique credentials. Cloudmed's domain resides solely within an isolated cloud environment with access controlled by AD. Web servers are hosted by Azure Cloud and access-controlled with AD authentication

- **Logging and Monitoring** - Cloudmed deploys reasonable, cost effective SIEM (Security Information and Event Management) and DLP tools to record user activities, exceptions, and information events in Cloudmed's information technology environment for all applications, operating systems, security devices, and network devices. Monitoring includes privileged operations, authorized access or unauthorized access attempts, including attempts to access deactivated accounts, and system alerts or failures.

- **Backups, Restoration, and Deletion** - The key to data backups is first determining what data should be backed up. Cloudmed determines that all critical data to Cloudmed's operation and/or employee job function and all information stored on the corporate file servers and email servers needs to be on a defined and complete backup schedule. It is the

user's responsibility to ensure any data of importance is moved to the file server. Backup frequency is critical to successful data recovery. Cloudmed has determined that the following backup schedule will allow for sufficient data recovery in the event of an incident, while avoiding an undue burden on the users, network, and backup administrator. The backup schedule may be adjusted, at the IT Manager's discretion, to be more frequent and/or comprehensive but no longer or less comprehensive than the requirements specified in this policy. The IT Manager may evaluate each system and dataset individually to determine the criticality of each and apply appropriate scheduling.

- Shadow Copy: Twice a day
- Incremental: nightly
- Full: every week

Geographic separation from the backups must be maintained, to some degree, in order to protect from fire, flood, or other regional or large-scale catastrophes. Offsite storage is balanced with the time required to recover the data, which must meet the Cloudmed's uptime requirements. Backup media must be rotated off-site at least once per month. Storage of backups is a serious issue and one that requires careful consideration. Since backups contain critical, and often confidential data, precautions are taken that are commensurate to the type of data being stored. The following guidelines are in place for backup storage:

- When data is stored onsite, backup media is stored in a fireproof container in an access-controlled area. Backups are also stored on redundant storage arrays.
- When backups are stored offsite, a hardened facility (i.e., commercial backup service) that uses accepted methods of environmental controls, including fire suppression, and security processes are used to ensure the integrity of the backup media.
- If a backup service is used, rigorous security procedures are developed and maintained, to include, at minimum, credential-verification, and signature of the backup service courier. Online backups are allowable if the service meets the criteria specified therein. Confidential data is encrypted using industry-standard algorithms to protect against data loss.

When determining the time required for backup retention, Cloudmed determines what number of stored copies of backup-up data is sufficient to mitigate the risk effectively while preserving required data.

Cloudmed has determined that the following meets all requirements:

- Incremental Backups must be saved for one month.
- Full Backups must be saved for one year.
- Snapshots are taken nightly and kept for 30 days.

Data restoration procedures are tested and documented. Documentation includes exactly who is responsible for the restore, how it is performed, under what circumstances it is performed, and how long it takes from request to restoration. It is extremely important that

the procedures are clear and concise such that they are not misinterpreted, or confusing during a time of crisis. Since backups are not useful if the restoration process fails, Cloudmed tests the restore procedures periodically to eliminate potential problems. Backup restores are tested when any change is made that may affect the backup system, as well as twice per year. Certain types of backup media, such as magnetic tapes, have a limited functional lifespan. After a certain time in service, the media can no longer be considered dependable. When backup media is put into service, the date is recorded on the media. The media is then be retired from service after its time in use exceeds manufacturer specifications.

- **Software Sources** - Cloudmed maintains a list of applications, operating systems and all critical software needed to run the system and its operations. The list is kept up to date. Software and hardware assets are tracked and managed in order to reconcile compliance with licensing agreements. Adequate controls are in place to ensure that all software being used by the Company is in compliance with the terms and conditions for the software and applicable regulations as they pertain to the laws that govern the use of software.

- **Secure Data Transfer** - Data transfer for new projects or for change of scope on an existing project must be validated by the CISO prior to any data transfer. Any data transfer using portable media must be approved and vetted by CISO any time it is requested. CISO also verifies that portable media is encrypted prior to transfer. Electronic data transfers must use approved, encrypted methods with unique credentials such as SFTP, secure share file sites, or encrypted emails. The approval, establishment, and termination of data transfers must be logged and documented with pertinent details. Encryption mechanisms must meet the minimum industry and government standards.

People

Leadership Team

Lee Rivas – *Chief Executive Officer*
Lee Rivas joined Cloudmed as the Chief Executive Officer, bringing over 20 years of leadership experience in technology and healthcare. Prior to joining Cloudmed, Lee served as a senior leader at RELX, a global provider of information analytics solutions and most recently served as CEO of all Healthcare and Public Sector businesses across the LexisNexis Risk Solutions and Elsevier Divisions. During Lee's tenure, he drove significant new market expansion in healthcare, ramped up capabilities around analytics offerings, and improved technology automation. Lee began his career as an officer in the U.S. Army where he held several leadership positions in the U.S. and abroad. Lee is a graduate of the United States Military Academy at West Point and holds an M.B.A. from Harvard Business School.

Kyle Hicok – *President and General Manager*
Kyle Hicok is the President and General Manager of Cloudmed, bringing over 17 years of healthcare industry experience with revenue cycle operations to the role. As President, Kyle leads solution execution and operations, overseeing the product implementation and customer service for all solutions. Prior to Cloudmed, Kyle was responsible for multi-state revenue cycle

operations, national consulting and shared service operations, and general management of revenue cycle technology and services organization.

Brian Neece – *President*
Brian Neece is the President of Cloudmed, bringing over 25 years of healthcare experience to his role. Brian joins Cloudmed from Triage Group, where he was a member of the Executive Team involved in project management and managing the firm's administrative and operational needs. Brian's industry experience also includes retail, software, and financial services. Brian received a BS in Information Systems from Rochester Institute of Technology and an M.B.A. in Finance from New York University.

Sean Alavi – *President*
Sean Alavi is the President of Cloudmed and has over 20 years of healthcare and revenue cycle experience. Sean joins Cloudmed from Triage Consulting Group, where he was a member of the Executive Team responsible for overseeing the East Coast operation. Sean also spent several years in the Management Consulting practice of Cap Gemini and the Corporate Strategies group of a Financial Services institution. Sean has an MBA from UNC Chapel Hill.

Kristina Bourke – *Chief Operating Officer*
Kristina Bourke is the Chief Operating Officer and has over 20 years of experience leading tech-enabled businesses. Prior to joining Cloudmed, Kristina served as Group Senior Vice President of Strategic Sourcing Partnerships and Programs for Vizient, a leader in healthcare services. During her tenure, Kristina drove the development and management of sourcing and supply chain strategies across healthcare. Kristina began her career with GE, where she held several leadership positions in services and supply chain. Prior to Vizient, she served as the General Manager of GE's Healthcare IT business across the Americas. Kristina graduated from Penn State University with a Mechanical Engineering degree and holds an M.B.A. from The Wharton School of Business.

Frank Forte – *Chief Revenue Officer*
Frank Forte is the Chief Revenue Officer for Cloudmed, bringing over 20 years of experience in healthcare, manufacturing, and technology. His strategic vision has resulted in rapid growth and market leading positioning. Frank is responsible for defining and executing the company's growth strategy. Before joining Cloudmed, Frank was Chief Business Development Officer at TVR Communications, the KLAS category leader for interactive patient systems. Prior to TVR, Frank held executive roles in business development, operations, and strategy for various divisions of Emerson Electric Corporation. Frank graduated from Worcester Polytechnic Institute with a degree in Mechanical Engineering and holds an M.B.A. from Rensselaer Polytechnic Institute.

Jennifer Williams – *Chief Financial Officer*
Jennifer Williams is the Chief Financial Officer and has over 20 years of progressive financial leadership across various data analytics and technology businesses. Most recently, Jennifer served as Senior Vice President and Chief Financial Officer of Corporate functions for Change Healthcare. During her tenure, she led the financial integration of the Change Healthcare and McKesson joint venture and the subsequent Initial Public Offering of the company. Prior to Change Healthcare, she was the corporate controller and global finance leader at First

Advantage. In addition, she held various leadership positions at ChoicePoint and LexisNexis Risk Solutions and began her career with Ernst & Young. She received her bachelor's degree and Master of Accountancy degree from Auburn University and is a Certified Public Accountant.

Sowri Krishnan – *Chief Technology Officer*
Sowri Krishnan joined Cloudmed as the Chief Technology Officer and has over 20 years of extensive experience building and directing global business and technology operations. As Chief Technology Officer, Sowri is responsible for all Security, Engineering/Development, and Infrastructure. Sowri's experience spans multiple countries, where he launched and managed operations and delivered business and technology solutions. He is a leader who encourages performance by mentoring and equipping teams for success and inspires creativity through the encouragement of entrepreneurial pursuits and cross-team collaboration.

Chris Jones – *Chief Human Resources Officer*
Chris Jones is the Chief Human Resources Officer, bringing over 20 years of progressive experience in professional services firms, with focused expertise in human capital and operations leadership. As CHRO, Chris is responsible for the management and direction of human capital programs. He is focused on strengthening employee engagement at the company as well as its customer-first culture. Prior to joining Cloudmed, Chris spent over eight years as a Managing Director at FTI Consulting where he was a demonstrated leader in Human Resources and Business and Sales Operations.

Procedures

Cloudmed has documented policies and procedures to support the operation and controls over the system. Specific examples of the relevant policies and procedures include the following:

- Information Security Management Program
- Information Security Policy
- Acceptable Encryption Policy
- Acceptable Use Policy
- Access Control Policy
- Business Continuity Plan
- Clean Desk Policy
- Data Backup Policy
- Data Classification Policy
- Email Policy
- Fraud, Waste and Abuse Policy
- Incident Response Plan
- Internet DMZ Policy
- Mobile Device Policy
- Network Security Policy
- Password Policy
- Physical Security Policy
- Remote Access Policy
- Risk Assessment Policy

- Software Installation Policy
- Technology Equipment Disposal Policy
- Third-Party Connection Policy
- Web Application Security
- Wireless Communication Policy
- Employee Internet Use Monitoring and Filtering Policy
- Security Awareness Policy
- Vendor Management Policy
- Audit Controls Policy
- Vulnerability Management Policy
- Onboarding and Offboarding Policy
- Viruses and Malware Policy

Data

The data flow begins with file transfers to Cloudmed Connect where the client may opt to use the HTTPS over TLS 1.2 protocol or use the SFTP protocol. Cloudmed Connect uses Cerberus FTP Server hosted on an Azure Server. It is encrypted and a temporary repository as internal, typically automated mechanisms pick up the files and transfer the files using secure, encrypted transmissions to internal Azure servers for storage, then processed or parsed through for validity and integrity checks and database processing rules for appropriate segregation in the multi-tenancy of the Data Lake system. Additional rules are applied to the data for initial revenue recovery processing, then the data is sent to the appropriate servers for presentation into the web application for user interface and auditing efforts and reporting.

Cloudmed uses a detailed method for classifying data and to specify how to handle the data once classified. The method includes all Cloudmed data stored on Cloudmed owned, Cloudmed leased, and otherwise Cloudmed provided systems and media, regardless of location. Also covered are hardcopies of Cloudmed data, such as printouts, faxes, notes, etc. Cloudmed requires that all data regardless of classification is stored on an encrypted SAN in the secured data center. In the event that data is not stored in the data center, it is required to be stored on an encrypted medium. All covered information is kept to minimum necessary and is purged annually for anything older than five years. Cloudmed owned equipment is marked with an asset tag that is either red or blue with a unique number and bar code. Every equipment with an asset tag is entered into an inventory tracking system with uniquely, identifiable information and when possible, items are cross-referenced with the MDM tool.

Data residing on corporate systems must be continually evaluated and classified into the following categories:

- ***Personal***: includes user's personal data, emails, documents, etc. This policy excludes personal information, so no further guidelines apply.
- ***Public***: includes already-released marketing material, commonly known information, etc. There are no requirements for public information.
- ***Operational***: includes data for basic business operations, communications with vendors, employees, etc. (non-confidential).

- ***Critical***: any information deemed critical to business operations (often this data is operational or confidential as well). It is extremely important to identify critical data for security and backup purposes.
- ***Confidential***: any information deemed proprietary to the business. Employee personal information (held by HR), PHI, and password credentials are examples of confidential information.

Data storage guidelines apply to storage of the different types of Cloudmed data.

- Operational data must be stored where the backup schedule is appropriate to the importance of the data, at the discretion of the user.
- Critical data must be stored on a Cloudmed supplied server that processes frequent backups. System or disk level redundancy is required.
- Confidential information must be removed from desks, computer screens, and common areas unless it is currently in use. Confidential information should be stored under lock and key (or keycard/keypad), with the key, keycard, or code secured.

Data transmission requires that strong encryption must be used when transmitting confidential data outside the Cloudmed's network. Confidential data should not be left on voicemail systems, either inside or outside the Cloudmed's network, or otherwise recorded.

Data Destruction requires crosscut shredding for document destruction. Storage media should be appropriately deleted or destroyed. If the data in question were also considered confidential, applicable policy statements would apply. Confidential data must be destroyed in a manner that makes recovery of the information impossible. The following guidelines apply:

- Crosscut shredding is required for paper/documents.
- Physical destruction is required Storage media (CD's, DVD's).
- Physical destruction is required Hard Drives/Systems/Mobile Storage Media.

If physical destruction is not possible, the IT Manager must be notified.

IV. OTHER RELEVANT ASPECTS OF THE CONTROL ENVIRONMENT, RISK ASSESSMENT PROCESS, INFORMATION AND COMMUNICATION SYSTEMS, AND MONITORING CONTROLS

The management of Cloudmed has established a system of internal controls aligned with multiple integrated frameworks. Cloudmed incorporates the COSO, NIST, and HITRUST frameworks in establishing internal controls. HIPAA guidelines are also incorporated into the design process of internal controls. The following processes describe management's approach to addressing the integrated frameworks.

Critical Business Functions

Control Environment – Cloudmed is committed to maintaining an organizational structure that supports an effective control environment. The control environment is comprised of various elements, including segregation of job duties, matching employee skill-sets with job functions, constant open communication between office personnel and management, management oversight, and significant checks and balances to assure integrity of data and information.

Human Resource Compliance **–** PHI is the company's biggest risk and is the core of the business. For protection purposes, Cloudmed requires an onboard process prior to exposure of resources and client information and an offboard process for terminating exposure to resources and client information. All personnel submit to a background check that includes photo ID for verification. HR retains the background check results in a personnel folder for every person. All personnel understand, agree, and sign security forms: Network Usage Policy, Non-Compete/Non-Disclosure Agreement, and HIPAA policy, no later than first day of employment. If a person does not pass the background check, the person does not join the team. Background checks must not have convictions or pending litigations involving felonies of any kind or misdemeanors for theft. If a person passes the background check and refuses to sign the security forms, then the person does not join the team.

A new hire ticket is used to confirm that the required standard employment documentation is collected for new hires. Documentation is retained within employee folders which are scanned into a document imaging system. Employees are required to sign the new hire package documentation. Managers authorize access for new system users to the system, e-mail, voice and data services, firewall request, and/or other software applications or databases which are required for the specific job. A security policy has been developed and documents the responsibilities resulting from system access. An acknowledgment form documents each employee's acceptance of system access responsibilities.

The company utilizes training and monitoring to prepare employees to perform their job functions. The Information Security Officer organizes at least one workshop or training seminar annually and the attendance is mandatory. All employees attend the security awareness training within 30 days from the date of employment and every twelve months thereafter. Completion of training is recorded and tracked either thru the Security team or Human Resources. The Information Security Officer uses online methods to deliver the awareness program such as SANS security awareness program, in addition to brochures, newsletters, and

weekly emails to increase Information Security awareness. It is the responsibility of every individual to keep themselves up to date through involvement in security program training. Failure to complete the security awareness training at least once annually will result in disabling access to network.

The employee's job responsibilities are reinforced through on-the-job training and specialized development programs such as supervisory skills training. All employees receive initial HIPAA and information security training upon hire at orientation, with HIPAA awareness training occurring biannually thereafter and information security occurring annually. Specific Information Security Policy and Procedure training is provided to the IT staff on an annual basis. An ongoing, security-awareness education program is in place via internal publications, presentations to leadership meetings, departmental meetings, and other venues as appropriate. Application security training is a critical first step to develop a secure application is an effective training plan that allows developers to earn important secure coding principles and how they can be applied. Examples of training courses that developers use to gain proficiency in secure coding principles are:

- SANS Software Security Training
- Defending Web Applications Security Essentials
- Secure Coding in Java/JEE
- Secure Coding in .NET
- Secure Coding in C & C++
- CERT Secure Coding Training
- Secure Coding in C and C++

Alternately, relevant books and reading material are also used to develop proficiency in secure coding principles, provided that sufficient time is allocated to staff for self-study.

An employee termination ticket is used to determine if necessary considerations are addressed. This list includes retrieving company property such as mobile phones, keys, security badges, and credit cards. In addition, this list includes the removal of system IDs. Personnel policies require immediate removal of employees who have been involuntarily dismissed. Building and information security officers are notified of terminations and transfers. Removal of access must be within 24 hours of termination for any employees, contractors, and third parties.

Security Requirements of Users

The security requirements of authorized users are broken down by the following matrix:

User Category	Privileges & Responsibilities
Department Users (Employees)	• Access is limited to application and databases as required for job function.
System Administrators	• Access to computer systems, routers, switches, and other infrastructure technology is limited to what is required for job function. Access to confidential information is on a "need to know" basis only.

User Category	Privileges & Responsibilities
Security Administrator	• Highest level of security clearance: Allowed access to all computer systems, databases, firewalls, and network devices as required for job function.
Systems Analyst/Programmer	• Access to applications and databases is limited to what is required for specific job function. User is not authorized to access routers, firewalls, or other network devices.
Contractors/Consultants	• Access to applications and databases is limited to the required for specific job functions. Access to routers and firewall only if required for job function. Be knowledgeable of security policies. Access to company information and systems must be approved in writing by the organization administration.
Other Agencies and Business Partners	• Access allowed to selected applications only when contract or inter-agency access agreement is in place or required by applicable laws.
General Public	• Access is limited to applications running on public Web servers. The general public will not be allowed to access confidential information.

User Access

Access Philosophy – It is the obligation of all users of the organization systems to protect the technology and information assets of the organization. Cloudmed information is protected from unauthorized access, theft, and destruction. Access controls exist at various layers of the system, including the network. Access control is implemented requiring, as a minimum, a unique logon (user ID) and password. At the application and database level, other access control methods are utilized to further restrict or manage access. The application and database systems can limit the number of applications and databases available to users, based on their job requirements. Access is implemented by least privileged, and then it is adjusted or increased as needed by user role changes. Cloudmed does not use group, shared, or generic accounts and passwords.

Application Access – Access rights to applications and application functions are limited to the minimum necessary using menus.

Sensitive System Isolation – Systems that are classified as having sensitive information such as FTI, PII, PHI, etc. are isolated physically and logically from non-sensitive systems. Controls are in effect to ensure that systems are properly secured and compliant with related standards. Appropriate monitoring mechanisms are in place to provide reasonable assurance that established controls are in effect. The isolated computing environment protects an application system based on the explicitly identified and documented sensitivity classification and associated requirements as documented by the application owner. Access to sensitive systems shall only be granted after approval from the system owner.

User Classification – All users are expected to have knowledge of Cloudmed policies and are required to report violations to their IT Administrator or supervisor. Also, all users conform to the Acceptable Use Policy. Only authorized administrators are allowed to implement approved upgrades to software, applications, and program libraries, based on business requirements and the security implications of the release. No changes are made without authentication.

User Systems and Network Access – New accounts are created after HR verifies ID and background check. User permissions are assigned based on role of the user in the company such as Auditor, Caller, Appeals, etc. Permissions are adjusted if role within the company is changed, and permissions are terminated according to company policy when users exit the company. All users will be required to have a unique logon ID and password for access to systems. The password is kept confidential and not shared with management & supervisory personnel and/or any other employee. All users must comply with the following rules regarding the creation and maintenance of passwords:

- Password must not be found in any English or foreign dictionary. That is, do not use any common name, noun, verb, adverb, or adjective. These can be easily cracked using standard "hacker tools".
- Passwords should not be posted on or near computer terminals, or otherwise be readily accessible in the area of the terminal.
- Password must be changed every 90 days.
- Logon IDs and passwords will be suspended after 90 days without use.
- Passwords are stored in encrypted password management tool that is stored on desktops or servers where applicable.
- Password history is set to twenty-four, preventing the re-use of any of the last twenty-four passwords.
- Mobile devices using PINs must have a minimum length of 6 characters.

Users are not allowed to access password files on any network infrastructure component. Password files on servers are monitored for unauthorized use. Copying, reading, deleting, or modifying a password file on any computer system is prohibited. Users are not allowed to logon as a System Administrator. Users who need this level of access to production systems request a Special Access Account.

Employees who forget their password must call the Information Services Help Desk to have their password reissued as a temporary password or use the online password self-reset service. The employee must identify by employee number and name to the IT department.

Employees are responsible for all transactions occurring during logon sessions initiated by use of the employee's password and ID. Employees must not logon to a computer and then allow another individual to use the computer, or otherwise share access to the computer systems. Access to printing is limited to users who work on-site at Cloudmed. Print jobs require a code to be entered directly into the printer before completing any print job.

Lockout/Timeout – Group policy enforces a screen saver lock, a session timeout, and account lockouts.

- Workstations have a screen saver lock at two minutes of inactivity.
- Sessions disconnect after thirty minutes
- Account lockouts occur after five failed logon attempts, within five minutes.
- Mobile devices requiring PINs are locked after ten failed attempts

Departures from Cloudmed - Employee Logon IDs and passwords are deactivated, as soon as possible, if the employee is terminated, fired, suspended, placed on leave, or otherwise leaves the employment of the Cloudmed. Contractors and any other users of the company's network will have Logon IDs and passwords deactivated as soon as access to the network is no longer needed. Supervisors/Managers directly contact the company IT Manager to report change in employee status that requires termination or modification of employee access privileges.

Privileged Access **–** Users who require privileged access for their duties receive separate accounts to perform these specialized functions. The passwords for these accounts meet the same password requirement as standard users; however, passwords require change every 60 days and after suspected compromise.

Special Access **–** Special access accounts are provided to individuals requiring temporary system administrator privileges in order to perform their job. Special access accounts have the permission of the user's Manager, IT Director, or Information Security and the accounts are monitored by the organization. Monitoring of the special access accounts is done by entering the users into a specific area and periodically generating reports for review and account management. The reports show who currently has a special access account, for what reason, and when it will expire. Special accounts expire after the approved days and are not automatically renewed, without written permission.

Connecting to Third-Party Networks **–** This is established to ensure a secure method of connectivity provided between the organization and all third-party companies and other entities requiring an electronic exchange of information with the organization. "Third-party" refers to vendors, consultants, and business partners doing business with Cloudmed, and other entities needing to exchange information with the organization. Third-party network connections are used only by the employees of the third-party and only for the business purposes of the organization. The third-party company will ensure that only authorized users are allowed to access information on the company network. The third-party entity does not allow Internet traffic or another private network traffic to enter the Cloudmed network. This applies to all third-party connection requests and any existing third-party connections. In cases where the existing third-party network connections do not meet requirements, a new connection is established that follows policy. All requests for third-party connections are made by submitting a written request for Cloudmed approval.

Connecting Devices to the Network **–** Only authorized devices are allowed to connect to the organization network(s). Authorized devices include PCs and workstations owned by Cloudmed that comply with the configuration guidelines of the organization. Other authorized devices include network infrastructure devices used for network management and monitoring. Wireless devices can connect to the network if they meet the standards supported by the wireless network. Devices that do not meet the present standard for wireless communications are not allowed to connect to the network. A special network, with wireless access is available

for patient and guest use. Access to this network is contingent upon acceptance of the Cloudmed Acceptable Use Policy. This network does not have access to the production network. Users are not authorized to attach any device that would alter the topology characteristics of the Network or any unauthorized storage devices, e.g. thumb drives, USB drives, and writable CDs.

Remote Access – Only authorized persons can remotely access the organization network. Remote access is provided to those employees, contractors and business partners of the organization that have a legitimate business need to exchange information, copy files or programs, or access computer applications. Authorized connection can be remote PC to the network or a remote network to organization network connection. Requirements for remote access include the following:

- Secure remote access must be strictly controlled with encryption (i.e., Virtual Private Networks (VPNs)) and strong passphrases.
- Authorized Users shall protect their login and password, even from family members.
- While remotely connected to Cloudmed's corporate network, authorized users shall ensure the remote host is not connected to any other network at the same time, with the exception of personal networks that are under their complete control or under the complete control of an authorized user or third party.
- Information Security Office and the appropriate business unit manager must approve use of external resources to conduct Cloudmed business in advance.
- All hosts that are connected to Cloudmed internal networks via remote access technologies must use Cloudmed approved anti-virus software. This includes personal computers.

Unauthorized Remote Access – The attachment of unauthorized devices to a user's PC or workstation that is connected to the organization network is not permitted, without written permission from the CISO, the CIO, or their Directors. Additionally, users are not authorized to install personal software designed to provide remote control of the PC or workstation. This type of remote access bypasses the authorized highly secure methods of remote access and poses a threat to the security of the entire network.

Printing Access – Printing is only permitted on network printers. AD Group permissions prevent unauthorized use of printers. Users must have a need to print that falls within the scope of their assigned duties. Every authorized user receives a code and must manually enters a code into the printer to access and release print jobs. Documents must be covered and secured at all times and properly disposed when no longer needed.

Change Management

The Information Resources infrastructure at Cloudmed is continuously changing and becoming more complex. As more people are dependent on the network, computers, and application programs and much of the environment is, it is critical that changes are managed and the need for a change management is essential. Managing these changes is a critical part of providing a robust and valuable Information Resources infrastructure. Changes require forethought, monitoring, and follow-up evaluation to reduce negative impact to users and to increase value

of Information Resources. The intended scope of Cloudmed's IT Change Management is to cover all of the computing systems and platforms. The primary IT functional and operation components may include:

- ***Hardware*** – installation, modification, removal or relocation of computing equipment
- ***Software*** – installation, patching, upgrade or removal of software products
- ***Database*** – changes to databases or files such as additions, reorganizations and major maintenance
- ***SDLC/Application*** – Software development life cycle and application changes to be promoted to production as well as the integration of new application systems and the removal and decommission of obsolete elements

The following change management process applies to all areas of IT. Cloudmed adopts industry best practices in all areas related to IT change management. A change is defined as a modification to the hardware, software, and documentation managed by IT that has possibility of impacting normal operations on IT resources. All changes must be documented and submitted for approval prior to implementation. The following defines the procedure for documentation and approval:

- The custodian requesting the change must fill out a ticket in the Help Desk System to obtain approval.
- The ticket is assigned to IT Administrator or other system administrator for review and approval. The administrator ensures accuracy and completeness. Change request tickets must be submitted to the administrator a minimum of one full business day prior to the review date.
- Changes to critical systems must be done in a test environment first.
- Implementation of a new system or changes that increase costs must be forwarded to CIO and Information Security Officer.
- Once a major change has been done, the Application custodian needs to do a formal procedure to the system in order to ensure the integrity of the system.
- Announcement messages must be distributed to users prior to the change. The IT or system administrator should prepare and distribute this announcement. Typically, user notification is made by email.
- It may occasionally be necessary to implement emergency changes which will be documented. Any changes that are planned within a period of 12 hours or less will be documented as emergency changes. An Incident Report must be completed for these changes.
- An Incident Report form must be filled out for any unplanned incident on the system (i.e. power outages).
- Any changes affecting computing environmental facilities (i.e. air-conditioning, water, plumbing, electricity and alarms) need to be planned with the ISO.
- A written change request must be submitted for all changes through the Help Desk ticket system.
- Emergency changes during business hours will only be acceptable in the event of a system failure.

- Unscheduled changes after business hours are acceptable in the event of a system failure or the discovery of a security vulnerability.
- Scheduled changes must be planned for after-hours or on weekends and coordinated with virtual service provider through the service provider's ticket system.

Information Security Audits

Cloudmed established and maintains appropriate and adequate audit controls to meet its due diligence in legal requirements for systems containing confidential or sensitive electronic information including ePHI. These controls are to be in place as a security standard for all applicable information systems. This is accomplished through the implementation of hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use confidential or sensitive electronic information, including ePHI. Cloudmed deploys reasonable, cost effective SIEM (Security Information and Event Management) and DLP tools to record user activities, exceptions, and information events in Cloudmed's IT environment for all applications, operating systems, security devices, and network devices. Monitoring includes privileged operations, authorized access or unauthorized access attempts, including attempts to access deactivated accounts, and system alerts or failures. Audit trails are maintained and regularly reviewed to determine sensitive events that are analyzed for out of tolerance conditions, possible fraudulent, and/or impermissible use of the system, such as repeated unsuccessful logons and access attempts over a series of days. Cloudmed has implemented the following process:

- Event and Log Manager Tool will record and maintain logs
- Logs are configured to record automatically and continuously
- Logs are stored and backed up indefinitely
- Logs are reviewed quarterly or when significant changes are made to the network
- Logs of messages sent and received are maintained including the date, time, origin and destination of the message, but not its contents
- AV report significant security events to the Security Office according to Incident Response Policy
- Authorized access and unauthorized access attempts to the organization's audit systems and audit trails is logged and protected from modification

The protection and retention of audit logs must include the following:

- Mechanisms must be established so that systems are not halted when logs become full and that logging continues with little or no disruption
- Access to online audit logs must be restricted
- Off-line storage of audit logs must be retained according to any applicable record
- Control must be in place to protect logs against unauthorized changes and operational problems such as the logging feature being de-activated, alterations to the message types recorded, log files being edited or deleted, and protection of log file media
- Establish separation of duties between personnel who administer the access control function, those who perform the logging of events, and those who review the logs

- Configuration settings must be documented and compared to actual setting to ensure unauthorized changes to logs have not occurred
- The organization system clocks are synchronized to an agreed, authoritative real-time standard daily and at system boot
- Time data is protected and controlled from unauthorized access

Network Engineering and Security

Cloudmed regularly reviews Azure services and controls, determining that policy requirements and service agreements are met or if any kind of adjustments are needed.

Routers and Switches
Every router must meet the same, pre-defined, 15-point configuration standards determined and implemented by Cloudmed.

Firewalls
The organization's security gateways enforce security policies and are configured to filter traffic between domains, block unauthorized access, and are used to maintain segregation between internal wired, internal wireless, and external network segments including DMZs and enforce access control policies for each of the domains.

Network Servers
Servers typically accept connections from a number of sources, both internal and external. Generally, the more sources that connect to a system, the more risk is associated with that system, so it is particularly important to secure network servers.

Intrusion Detection/Intrusion Prevention
Intrusion Detection System (IDS) and Intrusion Prevention System (IPS) technology is useful in network monitoring and security. IDS alerts to suspicious activity whereas an IPS blocks the activity. When tuned correctly, the IDS is useful but can generate a large amount of data that must be evaluated for the system to be of any use. The IPS automatically takes action when there are suspicious events, which can be both good and bad, since legitimate network traffic can be blocked along with malicious traffic.

Antivirus/Anti-Malware
Computer viruses and malware are pressing concerns in today's threat landscape. If a machine or network is not properly protected, a virus outbreak can have devastating effects on the machine, the network, and the entire Cloudmed.

Network Diagram
The network diagram is reviewed and updated, at least every 6 months or when there is a significant change to the network.

Network Services
Network services and system providers are formally managed and monitored to ensure the agreed services are provided securely. Network services and system providers are obligated to follow all applicable policies and procedures. Network services and system providers access

is role-based that will insure the right people with the right devices gain access to the right network resources.

Risk Management and Assessment

Cloudmed annually performs an Information Security Risk Assessment. The organization follows the risk management model as defined in NIST 800-30 as a guide. The Information Security Officer is responsible for facilitating the completion of the risk assessment and report to the executive management. Results from the annual assessment drive, capital budget requests, operating budget requests, and the risk mitigation plan. Management needs to decide either to accept the risk, transfer the risk, mitigate the risk, or avoid the risk. In the event that a specific application or function must deviate from the approved policy, an exception to policy process is in place.

Risk Assessment via Vulnerability Scans

The Information Security Officer performs network security scanning. The CISO utilizes software, to perform electronic scans on all devices on the Cloudmed network. This includes both Cloudmed-owned and non-Cloudmed owned devices. For example, this includes, but is not limited to all machines on the wireless networks, vendor hardware, and any personal machines that plugged into an organization's network port.

Vulnerability Scans are conducted to:

- Ensure integrity, confidentiality and availability of information and resources
- Ensure machines are patched against the latest vulnerabilities
- Ensure conformance to Cloudmed security policies
- Investigate possible security incidents

The IT department receives newly discovered vulnerabilities and risks, develops a remediation plan, and presents a final report to executive management. The execution, development and implementation of a "fix" or "patch" for vulnerabilities is the responsibility of the owner of the system. If expertise to fix the problem does not reside in the owning department, the director of the owning department requests assistance from the CISO to develop and implement a risk remediation plan. Employees cooperate fully with any Audit/Risk Assessments conducted on systems for which they are accountable. New machines receive Audit/Risk Assessments before plugging into the Cloudmed network. Any machine found to be vulnerable, un-patched or a vulnerable to exploitation is taken off the network until it is fixed.

Vulnerability Management

Cloudmed participates a comprehensive vulnerability management program with documented and accountable processes for identifying and addressing vulnerabilities, threats, and remediation within the organization's area of responsibility.

At least once a quarter and after significant changes are made, the IT Administrator scans for

vulnerabilities on computer systems, network devices, and security devices. The IT Admin utilizes software that includes Secure Content Automation Protocol (SCAP), to perform electronic scans on all devices on Cloudmed's network. IT Admins maintain secure system/application configurations by:

- Applying all applicable fixes, patches, and updates in a timely manner
- Routinely reviewing vendor sites, bulletins, and notifications
- Implementing vulnerability mitigation strategies in accordance with the organizational vulnerability management program

The vulnerability scanning activities update at least monthly or whenever new vulnerabilities are identified and reported from vulnerability intelligence services. Vulnerabilities are ranked according to severity, information is provided to IS staff and management, and remediation plans are developed according to rank. Vulnerability scans are stored for analysis. Previous and new scans are compared to confirm vulnerabilities were addressed and to determine if low risk items have not increased in risk level.

Penetration testing is a separate and distinctly different set of testing activities. Its primary focus is the exploitation (not just observation or assessment) of security vulnerabilities and therefore may be disruptive of operations (some exploits may cause operating systems or applications to "crash"). Penetration testing is most beneficial when executed after an Assessment has been performed and the issues found by that Assessment have been remediated.

Incident Management

Cloudmed holds incident management as one of its main priorities. The incident management plan for reporting information technology (IT) security incidents and initial reporting of any incidents that may involve the loss of PHI complies with reporting guidelines required internally and with contractual obligations with clients. Cloudmed is committed to protect sensitive information that is maintained by the company. In the event that sensitive and/or protected information is exposed due to a breach, Cloudmed must take the following steps:

- Prevent further exposure
- Investigate the incident and support law enforcement if criminal activity is suspected
- Determine any legal obligations
- Notify the Security Office and client or individual affected
- Document any responsive action(s) taken, and
- Conduct a post-incident review of these actions

Defining Security Incidents
Prior to any discussion on the incident response framework can begin, Cloudmed establishes the definition of a security incident. A security incident can have the following definitions:

- Violation of an explicit or implied security policy
- Attempts to gain unauthorized access

- Unwanted denial of resources
- Unauthorized use of electronic resources
- Modification without the owner's knowledge, instruction, or consent
- Theft or displaced Cloudmed IT property

The Incident Response Plan outlines the actions following a data breach or other type of data-related incident, for timeliness of response, compliance with applicable laws and regulations, and consistency of response. Incidents involving cyber security and privacy threats, such as viruses, malicious user activity, and vulnerabilities require a skilled and rapid response to mitigate likelihood and impact. These situations require a security-incident response capability as part of the contingency planning process.

Cloudmed defines a privacy incident as "a suspected or confirmed incident involving Protected Health Information (PHI)." PHI is any information that permits the identity of patient to be directly or indirectly to be inferred, including any information that might expose a patient's sensitive or private personal information. A privacy incident is an adverse event or action that is unplanned, unusual, and unwanted that happened due to non-compliance with the privacy policies and procedures. It must pertain to the unauthorized use or disclosure of PHI including "accidental disclosure" such as misdirected e-mails or faxes.

For breaches involving unsecured PHI, the Health Information Technology for Economic and Clinical Health (HITECH) Act requires HIPAA covered entities and their business associates to provide notification following a breach of PHI. It requires covered entities to provide the HHS Secretary with notice of breaches of unsecured protected health information. The specific processes for breach notification involving unsecured PHI are available from the HHS Office for Civil Rights (OCR).

Incident Response

The security incident response program accounts for and prepares the organization for a variety of incidents. Cloudmed's program includes an Insider Threat Program and training on how to recognize potential threats and security incidents. The Incident Response Plan addresses following types of information:

- Computing Devices Compromised by Malware
- Computing Devices Compromised by Unauthorized Access
- Lost or Stolen Computing Devices
- Lost or Stolen Paper Records containing Confidential Data
- Loss of or Unauthorized Access of Data

Incident response includes all computing devices and all paper records that contain confidential data. All Cloudmed employees/ staff that maintain or access confidential data, both paper and electronic comply with this plan.

Incident Responsibilities

Cloudmed's Chief Information Security Officer (CISO) is charged with the identification of all data security incidents that involves electronic data or paper records where the loss, theft,

unauthorized access, or other exposure of confidential data is suspected. When the CISO confirms an incident involving confidential electronic data, the CISO alerts the Incident Response Team (IRT). The CISO serves as the chair of IRT. If the CISO is unavailable, the designated senior technology leader assumes the role of chair. The chair of the team coordinates the IRT and determines appropriate actions in response to the breach. The Incident Response Team includes representatives from departments such as Legal, HR, IT, CTO, CEO, and the CISO. The IRT determines which additional members from Cloudmed responds to the breach, depending on the nature of the incident and the type(s) of information involved. The Chair oversees the investigation and involves legal counsel, local, state, and federal law enforcement as necessary. The severity of the breach determines the nature of the investigation, including what authorities are involved and how evidence is collected. The CISO documents all breaches and responsive actions taken. All employees/staff are responsible for identifying and reporting potential security breaches.

Incident Response Procedures

Notification – The Security Team and the CISO are to be notified of all incidents, and all incidents are to be documented. Notifications can be submitted anonymously by phone or by email without repercussions.

Response Categories – For this plan, two event types merit a response. There are computer and network related incidents that affect the Integrity, Confidentiality, and Availability of information, and illegal or illicit activities that involve Cloudmed information resources or staff. Computer and Network Incidents can be classified as the following

- Loss of confidentiality of information (Unauthorized Access/Theft)
- Compromise of integrity of information (Unauthorized modification or deletion of
- information)
- Loss of System Availability (Denial of Service)
- Misuse of Service
- Damage to Systems (Malicious Code Attacks)
- Network Probes
- Violations in Policy

Priority and Urgency – The IRT addresses all types of computer security incidents, which occur or threaten to occur. The level of support given by IRT depends on the type and severity of the incident, who is affected, and available IRT resources. In all cases, a response is made within one working day. Resources are assigned according to the following priorities, listed in decreasing order.

- ***High*** - These incidents can potentially affect human life or cause irreversible loss/damage to resources, e.g. Threats to the physical safety of human beings, root or system level attacks to any host or system, unauthorized access to confidential or protected information. They may also affect the integrity, availability, or confidentiality of the data, which may result in direct loss of business and/or reputation. Loss or exposure of large amounts of sensitive information justifies this priority level.

- ***Medium*** – These incidents typically affect the availability of information, not data integrity, or confidentiality. Examples include: Denial or service attacks to infrastructure, confidential service accounts or software areas, large-scale attacks of any kind i.e. worms, sniffing attacks, etc. Medium priority incidents have some impact to business operations, but there is minimal loss or compromise of information.
- ***Low*** – These incidents may affect the confidentiality, integrity, or availability of data; however, no loss of the data or service has occurred. Examples include: Threats, harassment, or criminal offenses involving individual user accounts, compromise of individual user accounts and desktop systems, forgery, misrepresentation, or misuse of resources, denial of service on individual accounts; inadvertent disclosure of confidential or protected information to unauthorized person.

Incident Response Team (IRT) – The IRT is established to provide a quick, effective, and orderly response to computer-related incidents such as virus infections, hacker attempts, and break-ins, improper disclosure of confidential information to others, and other events with serious information security implications. The IRT's mission is to prevent a serious loss of profits, public confidence, reputation, or information assets by providing an immediate, effective, and skillful response to any unexpected event involving computer information systems, networks or databases. The IRT is authorized to take appropriate steps deemed necessary to contain, mitigate, or resolve a computer security incident. It is responsible for investigating and documenting suspected security incidents in a timely, cost-effective manner, and reporting findings to management and the appropriate authorities as necessary. The CISO coordinates these investigations. The IRT subscribes to various security industry alert services to keep informed of relevant threats, vulnerabilities, or alerts from actual incidents.

Incident Handling Process – All incidents require a completed Incident report. The CISO serves as the point of contact who is responsible for coordinating incident responses and has the authority to direct actions required in all how incidents are handled. If the incident involves law enforcement or has legal ramifications, then it is important to preserve the scene, document the situation, and not destroy evidence that may reside within the system. It is highly recommended that the CISO is involved, and a trained Computer Forensics expert be used. The ISO serves as the point of contact for coordinating incident responses and has the authority to direct actions required in all phases of the process.

Disciplinary Action and Sanctions – Upon completion of investigations, disciplinary actions and sanctions adhere to the Company Disciplinary policy. The company cooperates with all Federal and State investigations and sanctions, and not cooperating will trigger disciplinary actions. Further, the company includes specific procedures for license, registration, and certification denial or revocation and other disciplinary action. All licensed Cloudmed Medical staff members will comply with state and federal rules and regulations, including credential requirements. When applicable, incidents that involve the licensed medical staff are reported to state and/or federal agencies. A list of employees involved with security incidents is maintained with the resulting outcome of the investigation. Management reserves the right to terminate or discipline any employee in the individual circumstances. All disciplinary actions are documented in the individual employee folders. Disciplinary actions include the following:

- Verbal Warning
- Written Warning
- Written Warning with possible loss of Pay and/or suspension
- Written Warning with Termination

Security Incidents During the Period
Cloudmed has well-established Incident Management Procedures in place that consist of documented incident response plans, incident response categories and priority levels, a dedicated incident response team (IRT) and a specified handling process.

Cloudmed diligently responds to alerts received from various monitoring tools deployed at the perimeter of the network, within the network, and applications. During the course of the audit period, Cloudmed dealt with multiple malware and viruses that were confined to a single endpoint, meaning it did not spread. The affected devices were cleaned or replaced according to levels of corruption.

Other types of incidents were lost mail or unencrypted emails with PHI or other confidential information. Applicable parties were notified of events and actions were documented.

Physical Security

Every employee with a key to the building also has a unique code to the alarm system. The IT department maintains the list of users with keys and unique alarm codes. Upon separation from the company, HR or the immediate supervisor acquires the key, and IT deactivates the unique alarm code immediately. All personnel are assigned a unique badge that grants entry through the gate and the doors according to their job roles and work schedules. Upon separation from the company, HR or the immediate supervisor acquires the badge and returns it to the IT department for deactivation within 24 hours of notification for a regular user and 60 minutes for a privileged or high-risk user. Only authorized IT and building maintenance have access to the server room. Each person has a unique code for accessing the server room. Any other person requiring access to the server room is escorted. The IT department maintains the list of authorized users. Upon separation from the company, the IT department deactivates the unique access code within 60 minutes of notification. All visitors are supervised unless their access has been previously approved. Access by third-party support personnel is restricted to secure areas or covered information processing facilities only when required, authorized, and monitored.

Environmental Security

Fire Extinguishers and detectors are installed according to applicable laws and regulations. Controlled areas are where sensitive information (e.g., covered information, payment card data) is stored or processed. They are controlled and restricted to authorized individuals only. Areas include but are not limited to Auditing Row and Calling Row. A map of the facility showing the areas of sensitive information is maintained, reviewed, and updated annually.

Repairs or modifications to the physical components of a facility that are related to security (e.g., hardware, walls, doors, and locks) are documented and retained in accordance with the organizational policies. All changes to the building's security aspects are coordinated with the IT department and maintenance team. Unless urgent, all changes are approved by Executive Management. Tickets are created in the IT Help Desk to track changes that affect security of the building and are kept for a minimum of 1 year. Maintenance and services are controlled and conducted by authorized personnel in accordance with supplier-recommended intervals, insurance policies, and organizations maintenance program.

Anti-Virus and Anti-Malware

Cloudmed's mission is to provide a virus-free network environment and to establish base requirements that must be maintained by computers connected to the network to ensure effective virus detection and prevention. This applies to all computers that are connected to Cloudmed's network via a company network connection, a wireless connection, a wired or LAN connection, or a VPN connection. This covers computers that are attached to the network regardless if they are company-owned and non-company owned devices. This also covers all types of computers including, but not limited to, desktop computers, laptop computers, mobile devices, and personal computing devices that are owned and/or used by staff and connect to the network.

All computers that are connected to the network have the standard supported anti-malware software installed and scheduled to run in real time. The provided anti-malware includes anti-virus and anti-spyware. In addition, the anti-malware software and the virus and spyware definition files are kept up to date. All computing devices are configured to receive regular updates. Any activities with the intention to create and/or distribute malicious programs into Cloudmed's network (e.g., viruses, worms, Trojan horses, e-mail bombs, etc.) are prohibited.

Virus-infected computers are removed from the network until they are verified as virus-free. Cloudmed requires anti-malware, anti-virus, and anti-spyware on all devices connected to Cloudmed's network, regardless of OS type. Scans and update settings match the company standard. Minimum allowed anti-malware scans are at boot-up and every 12 hours for critical system files. Anti-malware logs of significant events and scan histories are retained up to 1 year with 90-day and 1-year reports. Where possible, logs are sent to SIEM per the Audit Controls Policy.

Vendor and Supplier Management

In order to protect the organization information systems and data and meet its due diligence requirements Cloudmed has established the following requirements for third party assurance:

- A contract/agreement reflecting the security requirements is signed, acknowledging they understand and accept their obligations of doing business with Cloudmed.
- All remote access connections between the organization and third parties are encrypted.
- Access granted to external parties is limited to the minimum necessary and granted only for the duration required.

- Service Level Agreements or contracts with an agreed service arrangement address liability, service definitions, security controls, and other aspects of services management.
- A standard agreement with third-parties is defined.
- The results of monitoring activities of third-party services are compared against the Service Level Agreements or contracts at least annually.
- Third parties coordinate, manage, and communicate changes to their services provided to the organization.
- When software development is outsourced, formal contracts must address the ownership and security of the code and application and the development process is monitored by the organization and includes independent security and code reviews.
- Due diligence of the external party includes interviews, document review, checklists, certification reviews or other remote means.
- Specific limitations of access, arrangements for compliance auditing, penalties, and the requirement for notification of third-party personnel transfers and terminations are identified in the agreement with the third-party.
- The organization develops, disseminates, and annually reviews/updates a list of current service providers.
- Regular progress meetings are conducted as required by the SLA to review reports, audit trails, security events, operational issues, failures and disruptions, and identified problems/issues are investigated and resolved.
- Network services can be periodically audited to ensure that providers implement the required security features and meet the requirements agreed with management, including new and existing regulations.
- Third party service changes are evaluated to identify the potential impacts before implementation.
- The organization employs a service management relationship and process between itself and a third party for monitoring requirements.
- Organizations obtains satisfactory assurances that reasonable information security exists across their information supply chain by performing an annual review, which shall include all partners/third party-providers upon which their information supply chain depends.

Cloudmed meets HIPAA and HITRUST requirements for vendor management by assessing suppliers and/or vendors who undergo Cloudmed's procurement process with regard to the ability to comply with Cloudmed's requirements. Information Security provides their supplier and/or vendor status and conclusion to the Business Owners, Business Owner Delegates, and Information Security Officer. Cloudmed workforce members are responsible for ensuring any supplier and/or vendor goes through procurement. Any identified supplier and/or vendor who has not gone through procurement is subject for immediate review and potential service or payment hold, suspension/interruption.

Changes to the System during the Period

The changeover to Data Lake as the main consolidated database system is the most significant change during the audit period. Also, URL for public-facing sites changed from URLs for

legacy companies to Cloudmed URLs.

During the audit period and currently, Cloudmed technology is merging with acquired companies, consolidating processes and tools. This includes a continual change or adjustments to IT staff in various disciplines from Infrastructure, Development, to Cloud Management. This meant a continual restructure process throughout the year.

V. SUBSERVICE ORGANIZATIONS

Cloudmed uses a subservice organization to perform certain functions that support the delivery of services. The scope of this report does not include the controls and related Trust Services Criteria at the subservice organization. The following is a description of the services provided by the subservice organization and the controls that are expected to be implemented:

Subservice Organization	Services Provided
Microsoft Azure (Azure)	Cloudmed uses Azure to provide infrastructure cloud services.
ADAR IT	Provides virtual desktops and servers within the ADAR IT datacenter with firewall and network protection and 24x7 support.
Virtacore	Provides VMWare hosting of servers maintained by Cloudmed employees and hosting of virtual networks and firewalls with customer support as needed for networks and firewalls.

The following table presents controls that are assumed to be implemented by the subservice organization, which Cloudmed has identified as necessary to achieve certain Trust Services Criteria stated in the system description.

Trust Services Criterion	Complementary Subservice Organization Controls
CC 4.1 – The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	• Logging and monitoring software is used on a continuous basis to collect data from the system infrastructure components. The data is utilized to assess controls, performance, security threats, vulnerabilities, and unusual system activity. • Incidents affecting the availability, performance, or security. The identified incidents are reported to management.
CC 4.2 – The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	• Operations and security personnel follow defined protocols for assessing events through resolution of the event. • Management review the reported events for severity and determine the appropriate mitigation strategies for such events.

Trust Services Criterion	Complementary Subservice Organization Controls
CC6.1 – The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	• Logical access to offline storage, backup data, systems and media requires authorization, and access is reviewed periodically. • Firewalls and intrusion prevention systems are used and configured to prevent unauthorized access. The events are logged and reviewed. • Intrusion detection systems (IDS) are in place to monitor Web traffic and identify potential patterns or threats. • All access to system components requires that users are authenticated through unique user IDs and passwords.
CC 6.4 – The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.	• Procedures have been established to restrict physical access of the datacenter to authorized employees, contractors, vendors, and visitors. • Security verification check-in are required for personnel requiring temporary access to the interior datacenter facility. • Physical access to the datacenter is reviewed quarterly and verified by the management team. • Physical access mechanisms have been implemented to restrict access to authorized individuals. • The datacenter is monitored 24x7 by security personnel.
CC6.6 – The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	• Firewalls and intrusion prevention systems are used and configured to prevent unauthorized access. The events are logged and reviewed. • Intrusion detection systems (IDS) are in place to monitor Web traffic and identify potential patterns or threats.
CC6.7 – The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	• VPN, SSL, secure file transfer program (SFTP), and other encryption technologies are used for defined points of connectivity and to protect communications between the processing center and users connecting to the processing center from within or external to customer networks. • Data loss prevention software is used to scan for sensitive information in outgoing transmissions over public communication paths. • Backup media is configured to be encrypted.

Trust Services Criterion	Complementary Subservice Organization Controls
CC7.3 – The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	• Operations personnel follow defined protocols for evaluating reported events. Security related events are assigned to the security group for evaluation. • Real-time replication is performed using an automated system. • External users are informed of incidents in a timely manner and advised of corrective measure to be taken on their part. • A root cause analysis is prepared for all high severity incidents. Based on the root cause analysis, change requests are prepared and the entity's risk management process and relevant risk management data is updated to reflect the planned incident and problem resolution.

Monitoring of Subservice Organizations

In addition to obtaining SOC reports, Cloudmed monitors subservice organizations throughout the contract periods by reviewing any incidents involving physical and environmental security controls made available to the public. Cloudmed reviews incidents to ensure contract compliance, effectiveness and cost-beneficial acquisition of the contracted services. Any issues arising from actual incidents received and management's expectations are investigated and addressed for additional action. Cloudmed also annually evaluates all subservice providers to ensure the highest quality standards are met.

VI. COMPLEMENTARY USER ENTITY CONTROLS

Cloudmed's controls were designed with the assumption that certain controls would be placed in operation at user organizations. In certain instances, the application of specific controls at user organizations is necessary to achieve certain control objectives included in this report.

The following list outlines controls that should be in operation at user organizations to complement the controls listed in section VII. The list does not represent a comprehensive set of all controls that should be employed by user organizations. User organizations' auditors should consider whether the following controls have been placed in operation at user organizations:

- The user organization should have policies and controls implemented for creating user credentials, assigning appropriate roles, reviewing user access and timely revoking user access of their users within Cloudmed's application.

- The user organization should have policies and controls implemented to control and monitor the type of data they input in the application, the accuracy of the data they input, choose the right fields / field types for data input and the consequent impact of any unnecessary sensitive data input in the systems.

- The user organization should have policies and controls for the use of passwords related to their User IDs used to access the application if they opt for integrating with their own SSO or where the application allows to customize the password policies.

- The user organization should have policies and controls implemented to ensure only the required data is configured to be made public using the available configurations in Cloudmed's application. User organization should have proper controls such as approvals if they choose to make PII data public.

- The user organization should have procedures to ensure that timely notifications are provided to Cloudmed of terminated Agreements and if there are any requirements for data deletion prior to the Agreement termination.

- The user organization should have procedures to ensure that only authorized employees have the ability to access data.

- Controls should be established to ensure that all data transmitted by the user organizations to Cloudmed is complete, accurate, timely, and protected.

VII. INDEPENDENT SERVICE AUDITOR'S DESCRIPTION OF TESTS OF CONTROLS AND RESULTS

SECURITY

CONTROL ENVIRONMENT

CC1.1: The entity demonstrates a commitment to integrity and ethical values.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC1.1.1	Personnel are required to read and accept the code of conduct and the statement of confidentiality and privacy practices upon their hire and to formally re-affirm them annually thereafter.	For a sample of new employees, obtained and inspected the signed code of conduct to determine that new employees read and acknowledged upon hire. For a sample of current employees, obtained and inspected the signed affirmations to the code of conduct to determine that employees read and acknowledged annually.	Exception noted. No evidence of annual re-affirming of the code of conduct was provided for 2 of the 25 sampled current employees.
CC1.1.2	Documented workforce hiring policies and standards that include characteristics making candidates unfit for placement in position based upon the sensitivity or requirements of the position.	Obtained and inspected the employee handbook and hiring policies to determine that standards that may disqualify a candidate include consideration of the sensitivity or requirements of the position were in place and formally documented.	No exceptions noted.
CC1.1.3	Workforce hiring policies and standards are documented and include comprehensive background screening requirements for criminal background, drug screening, special exclusions, and appropriate special circumstance checks (i.e. credit checks or physical examinations).	For a sample of new employees, obtained and inspected the completed background checks to determine that new employees were screened for criminal background, drug screening, special exclusions, and appropriate special circumstance checks upon hire.	No exceptions noted.

Management Response to Exception Noted in CC1.1.1

Management visited with the HR team responsible for this area of our company. It was determined that the onboarding and training solution that was being used did not adequately track the new hire process, and that solution has since been replaced. Moreover, management has instituted safeguards to track onboarding paperwork.

CC1.2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC1.2.1	The board of managers meets at least annually to discuss relevant business and operation.	Obtained and inspected the board meeting minute documentation to determine that the board met annually and reviewed the state of the business and any year-to-date financials.	No exceptions noted.
CC1.2.2	The board of managers and officer information is outlined in the organizational documents.	Obtained and inspected the Board of Managers Roles and Responsibilities Charter to determine that officer information, including responsibilities, authorities, accountabilities, composition, and criteria were outlined and formally documented.	No exceptions noted.

CC1.3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC1.3.1	Organizational Chart maintained and updated by senior management as part of overall organizational planning activities. Updates are provided as needed or annually to ensure consistency with business objectives and requirements.	Obtained and inspected the current organizational chart and compared to the previous year's chart to determine that senior management maintained and updated the chart on an annual basis.	No exceptions noted.
CC1.3.2	Roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors.	Obtained and inspected a sample of job descriptions to determine that job roles and responsibilities were outlined and communicated throughout the organization.	No exceptions noted

CC1.4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC1.4.1	Job requirements are documented in the job descriptions and candidates' abilities to meet these requirements are evaluated as part of the hiring or transfer evaluation process.	For a sample of new employees, obtained and inspected the corresponding candidate resumes to determine that interview comments were recorded on the resumes and abilities were evaluated as part of the hiring process.	No exceptions noted.
CC1.4.2	Training program with hands-on, classroom, and on-line training modules supported by Daily Training Proficiencies developed for daily use, skill sets to drive the progressive development of skills, and a curriculum of training to ensure Compliance, Safety, Security, and process-specific training is current as needed.	For a sample of current employees, obtained and inspected screenshot evidence of the training statuses to determine that training curriculums were complete.	Exception noted. No evidence of completed training was provided for 2 of the 25 sampled current employees.

Management Response to Exception Noted in CC1.4.2

Management visited with the HR team responsible for this area of our company. It was determined that the onboarding and training solution that was being used did not adequately track the new hire process, and that solution has since been replaced. Moreover, management has instituted safeguards to track onboarding paperwork.

CC1.5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC1.5.1	Roles and responsibilities are defined in written job descriptions.	Obtained and inspected key positions job descriptions to determine that job roles and responsibilities were outlined and formally documented.	No exceptions noted.
CC1.5.2	Job descriptions are reviewed on a periodic basis for needed changes and updated if such changes are identified.	Obtained and inspected a sample of job descriptions to determine that job roles and responsibilities were outlined and communicated throughout the organization.	No exceptions noted.
CC1.5.3	Information Security Management Program documentation is maintained, reviewed on a no less than annual basis, and made available to employees.	Obtained and inspected the Information Security Management Program and Information Security policy documentation to determine that the program and policy was reviewed annually. Obtained and inspected screenshot evidence of the SharePoint site to determine that the program and policy was made available to all employees.	No exceptions noted.

COMMUNICATION AND INFORMATION

CC2.1: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC2.1.1	Cloudmed performs assessment at least annually to identify key information system processes that process relevant data into information to support the internal control and the achievement of the company's service commitments and system requirements.	Obtained and inspected the annual audit results performed by external assessors to determine that key information system processes that support the internal control and the achievement of the company's service commitments and system requirements were identified and evaluated by management. Obtained and inspected the annual internal risk assessment to determine that risk level and any suggested actions for each high-level risk were documented.	No exceptions noted.
CC2.1.2	Cloudmed has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained. Cloudmed has logical and physical security, change management, incident monitoring, and data classification, integrity, and retention controls, as necessary, with checks and balances woven into each applicable process to ensure quality of processing.	Obtained and inspected all relevant policies and procedures relating to security to determine that the standards were implemented throughout the organization. Obtained and reviewed logical and physical security, change management, incident monitoring, data classification, integrity, and retention policies and procedures to determine that checks and balances were woven into the process and were implemented throughout the organization.	No exceptions noted.

CC2.2: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC2.2.1	Contracts, Master Service Agreements (MSA) and/or Service Level Agreements (SLA) are executed and maintained. Compliance is responsible for reviewing the contracts and identifying requirements.	Through inquiry with management, determined the process for contract review and requirement identification by the Compliance team. For a sample of current clients, obtained and inspected the contracts, MSAs and SLAs to determine that contracts were executed and agreements were maintained.	No exceptions noted.
CC2.2.2	Mandatory on-boarding and annual training includes Information Security and Compliance training that encompasses security, confidentiality, and privacy.	For a sample of current employees, obtained and inspected screenshot evidence of the Information Security and Compliance training statuses to determine that training curriculums were complete.	Exception noted. No evidence of completed training was provided for 2 of the 25 sampled current employees.
CC2.2.3	Personnel are required to read and accept the entity's code of conduct and the statement of security, confidentiality, and privacy practices upon hire and annually thereafter.	For a sample of new employees, obtained and inspected the signed code of conduct to determine that new employees read and acknowledged upon hire. For a sample of current employees, obtained and inspected the signed affirmations to the code of conduct to determine that employees read and acknowledged annually.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC2.2.4	Cloudmed's policy and procedures documents for significant processes, which include responsibility for reporting operational failures, incidents, system problems, concerns, and user complaints (and the process for doing so), are published and available on the intranet.	Through inquiry with management, determined that a formal process is utilized to communicate changes in confidentiality practices internally via the SharePoint site. Obtained and reviewed screenshot evidence from the SharePoint site to determine that updates and changes to the policy and procedure documentation were communicated to all employees.	No exceptions noted.

Management Response to Exception Noted in CC 2.2.2

Management visited with the HR team responsible for this area of our company. It was determined that the onboarding and training solution that was being used did not adequately track the new hire process, and that solution has since been replaced. Moreover, management has instituted safeguards to track onboarding paperwork.

CC2.3: The entity communicates with external parties regarding matters affecting the functioning of internal control.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC2.3.1	System descriptions in the form of network diagrams, development documentation, and process flows are made available to appropriate personnel within the organization.	Obtained and inspected the network diagram and architecture review documentation to determine that boundaries of the system and the system components were in place. Through inquiry with management, determined that the network diagram and architecture review documentation were available upon request with the approval of senior management. Obtained and inspected email evidence to determine that management approval was required prior to obtaining the network diagram and architecture review documentation.	No exceptions noted.
CC2.3.2	System architecture and data flows are communicated to customers. Assignment of application and data administrators responsible for the function of these aspects, including the production of system documentation such as user guides and administrators guides, again are shared with customers, as applicable.	Obtained and inspected user manuals including assignment of application and data administrators responsible for the function of these aspects and the production of system documentation, to determine that system architecture and data flows were communicated to customers.	No exceptions noted.
CC2.3.3	Mandatory on-boarding and annual training includes Information Security and Compliance training that encompasses security, confidentiality, and privacy.	For a sample of current employees, obtained and inspected screenshot evidence of the Information Security and Compliance training statuses to determine that training curriculums were complete.	Exception noted. No evidence of completed training was provided for 2 of the 25 sampled current employees.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC2.3.4	Personnel are required to read and accept the entity's code of conduct and the statement of security, confidentiality, and privacy practices upon hire and annually thereafter.	For a sample of new employees, obtained and inspected the signed code of conduct to determine that new employees read and acknowledged upon hire. For a sample of current employees, obtained and inspected the signed affirmations to the code of conduct to determine that employees read and acknowledged annually.	Exception noted. No evidence of annual re-affirming of the code of conduct was provided for 2 of the 25 sampled current employees.

Management Response to Exception Noted in CC2.3.3 and CC2.3.4

Management visited with the HR team responsible for this area of our company. It was determined that the onboarding and training solution that was being used did not adequately track the new hire process, and that solution has since been replaced. Moreover, management has instituted safeguards to track onboarding paperwork.

RISK ASSESSMENT

CC3.1: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC3.1.1	Management meets semi-monthly to discuss business objectives, commitments and requirements, internal operations, and external factors that threaten the achievement of business objectives and update the potential threats to system objectives.	From a sample of months, obtained and inspected the bi-weekly meeting minutes to determine that business objectives, commitments and requirements, internal operations, and external factors were discussed and documented.	No exceptions noted
CC3.1.2	The entity management performs a risk assessment annually. The risk assessment is based on the objectives established by management. Assessed risks are reviewed to identify changes in underlying threats or in the environment that would require an update to assessed risks.	Obtained and inspected the risk assessment policy to determine that procedures were in place and formally documented. Obtained and inspected the annual risk assessment and corresponding risk register to determine that the risk assessment was completed and risks were reviewed and updated by management.	No exceptions noted.

CC3.2: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC3.2.1	Cloudmed performs comprehensive risk assessment process to identify threats to Company networks, systems, and operations specific to security. The assessment includes all critical functions and extends to cover any relevant third party that would provide critical services. Scoring parameters are set so risks can be quantified and addressed in accordance to severity. This process includes documentation, selection of mitigating strategies and controls, and remediation that are evaluated and accepted by management.	Obtained and inspected the risk assessment policy to determine that procedures were in place and formally documented. Obtained and inspected the annual risk assessment and corresponding risk register to determine that critical functions were addressed, risk ratings were in place by severity, and mitigation strategies and controls were reviewed by management.	No exceptions noted.
CC3.2.2	Use of security monitoring and management programs are utilized to monitor the security and health of network, including real-time notification alerts sent to security and network administration, log analysis tools, and reporting.	Obtained and inspected screenshot evidence of the Microsoft Defender Security Center to determine that security monitoring was in place and being utilized. Obtained and inspected screenshot and email evidence of notification logs to determine that real-time monitoring and reporting was in place.	No exceptions noted.
CC3.2.3	An internal Vulnerability Management program is in place to provide consistent oversight of vulnerabilities and remediation activities.	Obtained and inspected vulnerability scan history logs to determine that continuous recurring scans were performed and vulnerabilities identified on a continual basis. Obtained and inspected the vulnerability scan reports to determine that vulnerabilities were identified to provide oversight of remediation efforts.	No exceptions noted.

CC3.3: The entity considers the potential for fraud in assessing risks to the achievement of objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC3.3.1	Management has established measures to protect against unauthorized and willful acquisition, use, or disposal of assets.	Obtained and inspected Technology Equipment Disposal policy, the Equipment Disposal procedure, and NST Equipment disposal procedure to determine that measures to protect against unauthorized and willful acquisition, use, or disposal of assets were in place	No exceptions noted.
CC3.3.2	Management uses tools including a compliance hotline to help prevent fraud from its employees.	Through inquiry with management, determined a process was in place for monitoring fraud. Obtained and inspected the employee handbook, which includes fraud, waste, abuse, and hotline information to determine that employees were provided with the appropriate tools. Obtained and inspected screenshot evidence of the compliance hotline and employee compliance portal to determine that tools were in place and available to all employees.	No exceptions noted.
CC3.3.3	The board, audit committee, and management review Cloudmed's compensation and performance evaluation programs annually to identify potential incentives and pressures for employees to commit fraud.	Obtained and inspected the employee handbook to determine that compensation and performance evaluations were in place for employees and reviewed annually by the board, audit committee, and management.	No exceptions noted.

CC3.4: The entity identifies and assesses changes that could significantly impact the system of internal control.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC3.4.1	Changes are discussed with applicable techs/managers prior to making them. Changes are tracked in ticketing system.	For a sample of changes, obtained and inspected ticket evidence to determine that changes were tracked and reviewed by technicians or managers prior to implementation.	No exceptions noted.
CC3.4.2	Risks are discussed at the management level and discussions and decisions are reflected in meeting minutes.	Obtained and inspected the annual risk assessment and corresponding risk register to determine that the risk assessment was completed and risks were reviewed and updated by management. From a sample of months, obtained and inspected the bi-weekly meeting minutes to determine that business objectives, commitments and requirements, internal operations, and external factors and risks were discussed and documented.	No exceptions noted.
CC3.4.3	Quarterly meetings are performed for all Cloudmed employees as well as High-level announcements take place, as needed, for major updates at Cloudmed.	For a sample of quarters, obtained and inspected town hall meeting documentation to determine that quarterly meetings for all employees took place. Obtained and inspected company announcements and company newsletters, to determine that updates were communicated to all employees as needed.	No exceptions noted.

MONITORING ACTIVITIES

CC4.1: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC4.1.1	Monitoring software is used to identify and evaluate ongoing system performance, security threats, changing resource utilization needs, and unusual system activity. This software sends a message to the operations center and automatically opens an incident, problem, or change management "ticket" record when specific predefined thresholds are met.	For a sample of incidents and changes, obtained and inspected ticket evidence to determine that incidents and changes are logged and resolved by appropriate personnel in a timely manner. Obtained and inspected screenshot evidence of the alert notification settings, a sample alert email, and a sample alert ticket to determine that predefined settings and configurations were enabled and set to alert the IT team or create a ticket depending on severity of the detection.	No exceptions noted.
CC4.1.2	Operations and security personnel follow defined protocols for resolving and escalating reported events. A documented Security Event and Incident Management process, Standard Escalation Procedure, and Recovery/Response plans are in place to govern the process through identification, containment, investigation, notification, correction/remediation, review or analysis for preventative measures, and implementation.	Obtained and inspected the organizations Incident Response Plan to determine the processes of identifying, containing, investigating, notifying, correcting/remediating review or analysis for preventative measures, and implementation is implemented.	No exceptions noted.

CC4.2: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC4.2.1	Operations and security personnel follow defined protocols for resolving and escalating reported events.	Obtained and inspected the Incident Response Plan to determine that procedures were established for resolving and escalating reported events.	No exceptions noted.
CC4.2.2	Quarterly meetings are performed for all Cloudmed employees as well as High-level announcements take place, as needed, for major updates at Cloudmed.	For a sample of quarters, obtained and inspected town hall meeting documentation to determine that quarterly meetings for all employees took place. Obtained and inspected company announcements and company newsletters, to determine that updates were communicated to all employees as needed.	No exceptions noted.
CC4.2.3	The board and/or audit committee track the status of all deficiencies that have been rated as a serious threat to the organization until satisfactorily resolved.	Obtained and inspected the board meeting minute documentation to determine that the board met annually and reviewed the state of the business and deficiencies identified by management.	No exceptions noted.

CONTROL ACTIVITIES

CC5.1: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC5.1.1	Controls are integrated into business processes and system operations in a manner that allows the controls to be tested. Control testing occurs based upon the type of control and may include in-line testing (performed at time of action) and periodic testing by Controls Coordinators, Compliance, or designated practitioners within each relevant department.	Through inquiry with the Information Security Officer, determined that a process of real-time control testing for business processes and system operations occurred frequently by control coordinators, compliance, or designated practitioners and results were communicated to the Information Security Officer accordingly. For a sample of quarters, obtained and inspected meeting minute documentation to determine that business processes and system operations control testing was discussed.	No exceptions noted.
CC5.1.2	Annual recovery test conducted to ensure IT Recovery plan is sufficient to meet business needs.	Obtained and inspected the Disaster Recovery procedure to determine that a formally documented plan was in place and included annual recovery test plans. Obtained and inspected the annual Disaster Recovery test document to determine that a test was performed, reviewed by stakeholders and management, and remediations were documented.	No exceptions noted.
CC5.1.3	An internal Vulnerability Management program is in place to provide consistent oversight of vulnerabilities and remediation activities.	Obtained and inspected vulnerability scan history logs to determine that continuous recurring scans were performed and vulnerabilities identified on a continual basis. Obtained and inspected the vulnerability scan reports to determine that vulnerabilities were identified to provide oversight of remediation efforts.	No exceptions noted.

CC5.2: The entity also selects and develops general control activities over technology to support the achievement of objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC5.2.1	Management developed a list of control activities to manage the security access management risks identified during the annual risk assessment processes.	Obtained and inspected the annual risk assessment and corresponding risk register to determine that the risk assessment was completed, risks were reviewed and updated by management, and controls were developed based on high-level risk factors.	No exceptions noted.
CC5.2.2	Admin rights are controlled through separate domain accounts. Only users with necessary duties, have one of these admin accounts.	Performed a walkthrough of the admin access provisioning process with the Information Security Officer to determine how admin credentialing was controlled and approved based on responsibilities. Obtained and inspected screenshot evidence of admin accounts to determine that admin rights were restricted to authorized individuals who required access based on their job role and responsibilities.	No exceptions noted.
CC5.2.3	Capital purchases policies and procedures are maintained for any purchases made by Cloudmed.	Obtained and inspected the Fixed Asset policy relating to capital purchases to determine that a process was in place and formally documented.	No exceptions noted.

CC5.3: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC5.3.1	Policies are developed and maintained for key activities in the organization. These policies are developed by stakeholders and approved by management. Revision history is kept on these policies.	Through inquiry with the Information Security Officer, determined that a process was in place creating and maintaining policies and procedures regarding significant aspects of operations. Obtained and inspected all relevant policies and procedures to determine that a versioning table was in place and included approval from the CISO.	No exceptions noted.
CC5.3.2	Cloudmed has written job description specifying the responsibilities and the professional requirements for key job positions.	Obtained and inspected a sample of job descriptions to determine that job roles, responsibilities, and professional requirements for key job positions were outlined and formally documented.	No exceptions noted.

Supplemental Criteria: Logical and Physical Access Controls

CC6.1: The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.1.1	All new or modified user access to the Company network and critical applications requires authorization through Company's Employee Management Program. Access rights are provisioned based upon user role and job duties, requiring a clear and verified business need. The process includes segregation of duties between the parties involved in the assignment, request, and authorization of accesses. The Human Resources department identifies the user's classification level and the right associated with the role. The direct manager then validates the access meets the job requirements. Upon management verification, the access provisioning is sent the designated IT administrator and provisioned. A final Compliance validation occurs to ensure the provisioned access meets requirements and issues the final approval.	For a sample of user access requests, obtained and inspected the access request ticket to determine that HR initiated the process based on job role and responsibility, the appropriate manager approved the access request, the IT administrator provisioned the access request, and a tracking log was included in the ticket for final compliance validation approval.	No exceptions noted.
CC6.1.2	A role-based security process has been defined with an access control system that is required to use roles when possible.	Through inquiry with the Information Security Officer, determined that a role-based access provisioning process was in place. Obtained and inspected screenshot evidence of admin accounts to determine that admin rights were restricted to authorized individuals who required access based on their job role and responsibilities. Obtained and inspected screenshot evidence of the global, local, and Azure domain security groups to determine that role-based access when enabled when possible.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.1.3	Password complexity, history, and management standards are established to enforce control over access control passwords.	Obtained and inspected the password policy to determine that a password policy and procedure was in place and formally documented. Obtained and inspected screenshot evidence of the group password policy configurations to determine that complexity, history, and management standards were in place and enabled.	No exceptions noted.

CC6.2: Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.2.1	User account creation and modification is controlled through Company's Employee Management system. All requests for creation and modification are subject to a multi-step authorization and validation process with access rights provisioned based upon user role and classification. This includes privileged accounts.	For a sample of user access requests, obtained and inspected the access request ticket to determine that HR initiated the process based on job role and responsibility, the appropriate manager approved the access request, the IT administrator provisioned the access request, and a tracking log was included in the ticket for final compliance validation approval. Obtained and inspected screenshot evidence of admin accounts to determine that admin rights were restricted to authorized individuals who required access based on their job role and responsibilities.	No exceptions noted.
CC6.2.2	Cloudmed maintains an entitlement review process that validates all logical and physical access privileges are justifiable and aligned with Company policies.	Obtained and inspected screenshot evidence from the system to determine that all access privileges user controls to the system were continuously monitored. Obtained and inspected the Inactivity Report and Ticket Process to determine how inactive accounts were removed from the system.	No exceptions noted.
CC6.2.3	Cloudmed enforces password management standards that include enforced change of password upon initial sign-in. The documented standards also address controls for time-out, lock-out, and resets.	Obtained and inspected the password policy to determine that a password policy and procedure was in place and formally documented. Obtained and inspected screenshot evidence of the group password policy configurations to determine that change of password upon initial sign-in, time-out, lock-out, resets, and standards were in place and enabled.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.2.4	Upon termination or separation of employment for any associate, Human Resources notifies IT and Physical Security to remove access rights using an automated mechanism with the Employee Management system. The workflow includes notification, IT termination ticket, and verification steps to ensure each access is terminated. As IT and Physical Security manager each verify the access removal, a final validation occurs through Compliance.	For a sample of terminated employees, obtained and inspected the access termination ticket to determine that HR opened the ticket and notified the appropriate personnel, the ticket tracking log was maintained, and appropriate management reviewed and approved the termination requests through resolution.	No exceptions noted.

CC6.3: The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.3.1	Cloudmed maintains an Employee Management system to provision user accesses to Company networks and applications through an authorization process. All accesses are based upon role and business need.	Through inquiry with the Information Security Officer, determined that a role-based access provisioning process was in place. Obtained and inspected screenshot evidence of the onboard/offboard workflow to determine that an authorization process was in place and requests were based on role and business need.	No exceptions noted.
CC6.3.2	All users are required to authenticate using user account ID and password credentials before being granted access to Company networks. All access within Company's CDE is further controlled using multi-factor authentication include the Dell Defender token. All remote access is further controlled by Multi-Factor Authentication	Performed a walkthrough of the user authentication process to determine that users were required to sign in with a company account ID and password. Performed a walkthrough of the user authentication process within the CDE to determine that MFA was enabled and required use of a token. Performed a walkthrough of the remote access authentication process to determine that MFA was enabled and enforced.	No exceptions noted.
CC6.3.3	Entitlement review processes conducted and included confirmation that users require access to system resources. Any changes not already implemented are identified and escalated for remediation.	Obtained and inspected screenshot evidence from the system to determine that all access privileges user controls to the system were continuously monitored. Obtained and inspected the Inactivity Report and Ticket Process to determine how inactive accounts were removed from the system.	No exceptions noted.

CC6.4: The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.4.1	Company maintains secured facilities with access restricted to authorized personnel using an access control system (RFID proximity card).	Obtained and inspected the Physical Security policy to determine that physical security measures were in place and formally documented. Obtained and inspected video and image evidence of the company facilities to determine that and access control system was in place. Obtained and inspected the badge reader building access logs to determine that access was logged and restricted to appropriate personnel.	No exceptions noted.
CC6.4.2	Within the secured facility, restricted access areas are defined and protected by additional access control systems that include badge (RFID proximity card) or biometric access. Only authorized associates with verified business need are provided access to these areas. Such requirements are provisioned using Company's Employee Management system and are assigned by Human Resources, confirmed by management, and authorized by Compliance.	Obtained and inspected the Physical Security Policy to determine policies and procedures are implemented for badge access to the facilities. Obtained and inspected a video walkthrough of the facilities to determine only authorized users have access to the facility.	No exceptions noted.
CC6.4.3	Cloudmed maintains documented policy governing the roles allowed for access to restricted areas. Management of the accesses is administered through Company's Employee Management system.	Obtained and inspected the Physical Security policy to determine that physical security measures for restricted areas were in place and formally documented.	No exceptions noted.
CC6.4.4	All visitors (non-employees) must be escorted by a Company employee at all times. If the visit entails access to an area housing Company's sensitive system components or data, the visitor's entry to the restricted area must also be logged.	Obtained and inspected the Physical Security policy to determine that visitors were required to be escorted at all times. Per inquiry with management, visitors were not permitted during the audit period. Obtained and inspected company-wide announcements stating the policy was implemented.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.4.5	The sharing of access badges and tailgating are prohibited by policy.	Obtained and inspected the Physical Security policy to determine that the sharing of access badges and tailgating were prohibited by policy.	No exceptions noted.
CC6.4.6	Video surveillance at all entry/exit points, restricted access areas, and throughout facility are utilized to monitor access throughout the facility.	Obtained and inspected screenshot evidence of the video surveillance monitoring systems to determine that cameras were placed in strategic points throughout the facilities, including entry/exit points and restricted access areas.	No exceptions noted.

CC6.5: The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.5.1	Formal data retention and disposal procedures are in place to guide the secure disposal of the company's and customers' data.	Through inquiry with the Information Security Officer, determined that a process was in place to guide the secure disposal of company and customer data. Obtained and inspected the data classification policy, technology and equipment disposal policy, and equipment disposal procedures to determine that standards were in place and formally documented.	No exceptions noted.
CC6.5.2	Prior to removal from company facilities, all digital media is completely degaussed and sanitized to remove any data and software.	Obtained and inspected the Technology Equipment Disposal Policy to determine that procedures were established for removing any data and software from company facilities. For a sample of all data and software removed, obtained and inspected tickets to determine that digital media was completely degaussed and sanitized when removed from the system.	No exceptions noted.

CC6.6: The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.6.1	External points of connectivity are protected by a multi-tiered firewall infrastructure designed to prevent unauthorized connection and access. A firewall is in place to filer unauthorized inbound traffic from exterior sources.	Obtained and inspected screenshot evidence of the firewall configurations to determine that external points of connectivity were protected by a multi-tiered firewall infrastructure designed to prevent unauthorized connection and access.	No exceptions noted.
CC6.6.2	Firewall hardening standards are based on relevant applicable technical specifications and these are compared against product and industry recommended practices (to port level) and updated periodically.	Obtained and inspected the firewall hardening standards document and screenshot evidence of firewall rules to determine that standards were built upon industry recommended best practices. Obtained and inspected firewall audit documentation to determine that updates to the firewall rules and configurations were performed.	No exceptions noted.
CC6.6.3	Infrastructure hardening and configuration practices are applied including access controls. Critical software/application controls are administered by port level.	Through inquiry with the Information Security Officer and IT management, determined that hardening standards and configurations were reviewed and changed based on industry best practices. Obtained and inspected screenshot evidence that infrastructure hardening and configuration practices were applied, including access controls and that critical software/application controls are administered by port level.	No exceptions noted.

CC6.7: The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.7.1	VPN, IPSEC, secure file transfer program (SFTP), and other encryption technologies are used for defined points of connectivity and to protect communications between Company processing center and users connecting to the processing center from within or external to customer networks.	Obtained and inspected Duo VPN procedures to determine that VPN was required for remote access to the system. Obtained and inspected the network diagram and architecture review documentation to determine that boundaries were established for defined points of connectivity and to protect communications between Company processing center and users connecting to the processing center from within or external to customer networks.	No exceptions noted.
CC6.7.2	Company policy prohibits the transmission of highly sensitive information over the internet or other public communication paths (for example, email) unless it is encrypted. This includes enforcement of TLS and use DLP solutions.	Obtained and inspected the Information Security Management program and Information Security policy to determine that the policy prohibits the transmission of highly sensitive information over the internet or other public communication paths (for example, email) unless it is encrypted, including enforcement of TLS and use DLP solutions.	No exceptions noted.
CC6.7.3	Data loss prevention software is used to scan for sensitive information in outgoing transmissions over public communication paths.	Obtained and inspected screenshot evidence of the DLP tool to determine that data loss prevention software was enabled to scan for sensitive information in outgoing transmissions over public communication paths and alerts were generated if a threshold was crossed.	No exceptions noted.
CC6.7.4	Cloudmed uses a proprietary back-up system (Dell AppAssure) that is encrypted during creation.	Obtained and inspected the Data Backup policy to determine that a policy and procedure was in place and formally documented. Obtained and inspected screenshot evidence of the backup configurations to determine that backups were encrypted during creation.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.7.5	CDE workstations are encrypted based upon the type of information accessed. Operations and Data Processing workstations with full disk encryption.	Inquired with management and inspected backup documentation to verify that CDE workstations are encrypted based upon the type of information accessed. Also verified that Operations and Data Processing workstations utilize full disk encryption.	No exceptions noted.
CC6.7.6	Removable media usage is restricted through group policy application, with exceptions granted only to authorized personnel for legitimate business usage. In such cases, the removable media is encrypted.	Obtained and inspected the Information Security policy to determine that only approved personnel were allowed removable media usage. Obtained and inspected screenshot evidence from the system to determine that only approved personnel were allowed removable media usage.	No exceptions noted.

CC6.8: The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC6.8.1	Anti-virus software is installed on all workstations and laptops with configuration to scan and alert to malware or virus signatures on a continual basis.	For a sample of workstations and laptops, obtained and inspected screenshot evidence to determine that anti-virus software was installed and configured to scan and alert on a continual basis.	No exceptions noted.
CC6.8.2	Restrictions enforced to limit software and application installation on workstations and laptops to only authorized IT staff. No local administrative rights are permitted to users.	Obtained and inspected the Software Installation policy to determine that standard policies and procedures were in place and formally documented. Obtained and inspected screenshot evidence of the default device policies and restrictions to determine that configurations to restrict software installations was pushed to workstations and laptops. Obtained and inspected screenshot evidence of the IT admin configurations to determine that only role-based admins have the ability to install software and applications.	No exceptions noted.
CC6.8.3	Anti-virus software is configured to receive continual updates. IT and IS personnel monitor the status of devices and IT enforces updates upon connection to the network.	Obtained and inspected screenshot evidence of the anti-virus monitoring dashboard to determine that personnel continually monitor devices. Obtained and inspected the anti-virus logs to determine that personnel monitor and update devices on a continual basis. Obtained and inspected screenshot evidence to determine that anti-virus software was configured to scan and alert on a continual basis.	No exceptions noted.
CC6.8.4	Incoming email messages are subject to a multi-layer scanning process to identify spam, suspicious, and infected correspondence.	Obtained and inspected screenshot evidence or the malware and spam filter configurations to determine that email messages were subject to a multi-layer scanning process.	No exceptions noted.

Supplemental Criteria: System Operations

CC7.1: To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC7.1.1	An IT infrastructure monitoring tool is utilized to monitor IT infrastructure security and performance and generate alerts when specific predefined thresholds are met.	Obtained and inspected screenshot evidence of the defender security center platform to determine that a monitoring tool was in place to monitor IT infrastructure security and performance. Obtained and inspected screenshot evidence of the alert notification settings, a sample alert email, and a sample alert ticket to determine that predefined settings and configurations were enabled and set to alert the IT team or create a ticket depending on severity of the detection.	No exceptions noted.
CC7.1.2	Internal and external network vulnerability scans are performed quarterly. A remediation plan is developed, and changes are implemented to remediate all critical and high vulnerabilities at a minimum.	For a sample of quarters, obtained and inspected the vulnerability scan reports to determine that vulnerabilities were identified to provide oversight of remediation efforts.	No exceptions noted.

CC7.2: The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC7.2.1	Logging and monitoring software is used to collect data from system infrastructure components and endpoint systems and used to monitor system performance, potential security threats and vulnerabilities, resource utilization, and to detect unusual system activity or service requests. This software sends a real-time alert to IT and IS personnel for review.	Obtained and inspected the Sentinel daily review procedure documentation to determine that logging and monitoring procedures were in place and formally documented. Obtained and inspected screenshot evidence of the Sentinel console and alerting configurations to determine that logging and monitoring software is used to collect data from system infrastructure components and endpoint systems. Obtained and inspected screenshot evidence of the alert notification settings, a sample alert email, and a sample alert ticket to determine that predefined settings and configurations were enabled and set to alert the IT team for review.	No exceptions noted.
CC7.2.2	Cloudmed maintains an organizational information security team that meets regularly to address vulnerabilities and security posture of Company's information security management program.	Through inquiry with the Information Security Officer, determined that the information security team that met at defined intervals to discuss open vulnerabilities and security issues. For a sample of weeks, obtained and inspected the weekly security meeting minutes to determine that the team met regularly to discuss and remediate issues related to information security.	No exceptions noted.
CC7.2.3	Cloudmed maintains a Vulnerability Management program designed to incorporate vulnerability scanning of internal and external environments and management of vulnerability remediation.	Obtained and inspected vulnerability scan history logs to determine that continuous recurring scans were performed and vulnerabilities identified on a continual basis. Obtained and inspected the vulnerability scan reports to determine that vulnerabilities were identified to provide oversight of remediation efforts.	No exceptions noted.

CC7.3: The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC7.3.1	Cloudmed maintains protocols for addressing security and technical protocols for the redress of any incidents or events identified. Processes for addressing security-related or technical events and incidents (include physical or technical breach) are managed under Company's Information Security Management System (ISMS).	Obtained and inspected the Information Security Management Program and Information Security policy documentation to determine that the program and policy was reviewed annually. Obtained and inspected the Incident Response Plan to determine that the plan was in place and formally documented to address security-related or technical events and incidents	No exceptions noted.
CC7.3.2	The Change Management program is utilized to document, authorize, and validate the implementation of changes that are necessary to address permanent corrective or preventative measures related to incident response.	Obtained and inspected the Change Management policy to determine that a Change Management program was in place and formally documented. For a sample of changes, obtained and inspected ticket evidence to determine that changes were evaluated to address permanent corrective or preventative measures.	No exceptions noted.
CC7.3.3	Employee misconduct or non-compliance with company policies and procedures is addressed by disciplinary actions that include warning (probation), suspension, and termination as potential sanctions. The program allows for both progressive and severity-based application of disciplinary action.	Obtained and inspected the employee handbook to determine that misconduct or non-compliance with company policies and procedures was outlined, formally documented, and addressed types of disciplinary actions depending on the misconduct.	No exceptions noted.

CC7.4: The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC7.4.1	Management has established defined roles and responsibilities to oversee implementation of information security policies including incident responses.	Through inquiry with the Information Security Officer, determined that the CISO was charged with implementation of security policies, including the Incident Response Plan. Obtained and inspected the Incident Response Plan to determine that the plan was in place and roles and responsibilities for the Incident Response Team (IRT) were formally documented.	No exceptions noted.
CC7.4.2	Daily incremental and weekly full backups are configured for the database.	From a sample of dates, obtained and inspected the backup scan emails to determine that scans were completed successfully. From a sample of weeks, obtained and inspected the backup scan emails to determine that scans were completed successfully,	No exceptions noted.
CC7.4.3	All incidents related to the security of the system are logged, tracked, and communicated to affected parties by management until resolved.	Through inquiry with the Information Security Officer, determined that incidents were tracked through a ticketing system. For a sample of incidents, obtained and inspected the incident ticket to determine that incidents were logged, tracked, and communicated through resolution.	No exceptions noted.
CC7.4.4	Internal and external network vulnerability scans are performed quarterly. A remediation plan is developed, and changes are implemented to remediate all critical and high.	For a sample of quarters, obtained and inspected the vulnerability scan reports to determine that vulnerabilities were identified to provide oversight of remediation efforts.	No exceptions noted.

CC7.5: The entity identifies, develops, and implements activities to recover from identified security incidents.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC7.5.1	All incidents related to the security of the system are logged, tracked, and communicated to affected parties by management until resolved.	Through inquiry with the Information Security Officer, determined that incidents were tracked through a ticketing system. For a sample of incidents, obtained and inspected the incident ticket to determine that incidents were logged, tracked, and communicated through resolution.	No exceptions noted.
CC7.5.2	Cloudmed incorporates lessons learned from ongoing incident response activities into incident response procedures accordingly. If changes are required, necessary changes are made to the policy and procedures and redistributed according to all responsible organizations and key personnel.	Obtained and inspected the incident response plan to determine it is updated annually and changes are made to the policy if needed.	No exceptions noted.
CC7.5.3	Security administration team approval of changes is required prior to implementation.	For a sample of changes, obtained and inspected ticket evidence to determine that changes were evaluated and approved by the security administration team prior to implementation.	No exceptions noted.

Supplemental Criteria: Change Management

CC8.1: The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC8.1.1	The Change Management program is utilized to request, document, authorize, and validate the implementation of changes within the Company environment.	Obtained and inspected the Change Management policy to determine that a Change Management program was in place and formally documented. Performed a walkthrough of the Change Management process to determine that a formal workflow and process was utilized to track changes. For a sample of changes, obtained and inspected ticket evidence to determine that changes were evaluated to address permanent corrective or preventative measures.	No exceptions noted.
CC8.1.2	The Change Management process requires roll back and recovery planning for changes and implementations. This is used to ensure operations and back-out steps are planned.	For a sample of changes, obtained and inspected ticket evidence to determine that changes included roll back and recovery planning, including back-out steps.	No exceptions noted.
CC8.1.3	The change management process has defined the following roles and assignments: • Development - application design and support department • Testing of Critical Applications - development management • Implementation - change owner	Obtained and inspected the Change Management policy to determine that a Change Management program was in place and roles and responsibilities were formally documented. For a sample of changes, obtained and inspected ticket evidence to determine that responsibilities were segregated based on job role.	No exceptions noted.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC8.1.4	Cloudmed's Development management enforces an SDLC process that governs the development, acquisition, implementation, and maintenance of systems. The process includes appropriate identification of requirements, testing (static, dynamic), and administrative aspects of the process.	Obtained and inspected the Change Management policy to determine that a Change Management program, including SDLC steps, was in place and formally documented. Performed a walkthrough of the Change Management process to determine that a formal workflow and process was utilized to track changes. For a sample of changes, obtained and inspected ticket evidence to determine that steps were appropriately documented.	No exceptions noted.

Supplemental Criteria: Risk Mitigation

CC9.1: The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC9.1.1	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Obtained and inspected the risk assessment policy to determine that procedures were in place and formally documented.	No exceptions noted.
CC9.1.2	A risk assessment is performed on an annual basis. As part of this process, threats and changes to service commitments, policies, and procedures are identified and the risks are formally assessed.	Obtained and inspected the risk assessment policy to determine that procedures were in place and formally documented. Obtained and inspected the annual risk assessment and corresponding risk register to determine that the risk assessment was completed to address threats and changes to service commitments, policies, and procedures.	No exceptions noted.

CC9.2: The entity assesses and manages risks associated with vendors and business partners.

Control No.	*Control Activity*	*Test of Operating Effectiveness*	*Conclusion*
CC9.2.1	Formal information sharing agreements are in place with related parties and vendors. These agreements include the scope of services and security commitments applicable to that entity.	For a sample of vendors, obtained and inspected the signed contracts to determine that scope of services and security commitments were outlined and formally documented.	No exceptions noted.
CC9.2.2	Management has established defined roles and responsibilities to oversee implementation of information security policies.	Through inquiry with the Information Security Officer, determined that a process was in place creating and maintaining policies and procedures regarding significant aspects of operations. Obtained and inspected all relevant policies and procedures to determine that a versioning table was in place and included approval from the CISO.	No exceptions noted.
CC9.2.3	Cloudmed has documented and communicated security policies that define the information security rules and requirements for the service environment.	Obtained and inspected all relevant security policies to determine that information security rules and requirements for the service environment were clearly outlined. Obtained and inspected screenshot evidence of the SharePoint site to determine that relevant security policies were made available to all employees.	No exceptions noted.

VIII. ADDITIONAL INFORMATION PROVIDED BY THE INDEPENDENT SERVICE AUDITOR

Selection Criteria for Specific Tests

In selecting tests of the operating effectiveness of controls, we considered the

a) nature of the items being tested,
b) the types and adequacy of available evidential matter,
c) the nature of the trust services criteria to be achieved, and
d) the expected efficiency and effectiveness of the test.

Types and Descriptions of the Tests of Operating Effectiveness

Various testing methods are used to assess the operating effectiveness of controls during the examination period. The table below describes the various methods that were employed in testing the operating effectiveness of controls that are in place at the Company.

Testing Procedure	Description
Inquiry	Inquired of appropriate personnel and corroborated with management.
Observation	Observed the application or existence of the specific control as represented.
Inspection	Inspected documents and records indicating performance of the control.
Reperformance	Reperformed the control, or processing of the application control, for accuracy of its operation.

Procedures for Assessing Completeness and Accuracy of Client-Provided Information ("CPI")

For tests of controls requiring the use of CPI (for example, controls requiring system-generated populations for sample-based testing), we performed a combination of the following procedures where possible, based on the nature of the CPI, to address the completeness, accuracy, and integrity of the data or reports used:

a) inspect the source of the CPI,
b) inspect the query, script, or parameters used to generate the CPI,
c) tie data between the CPI and the source, and/or
d) inspect the CPI for anomalous gaps in sequence or timing to determine the data is complete, accurate, and maintains its integrity.

In addition to the above procedures, for tests of controls requiring management's use of CPI in the execution of the controls (for example, periodic reviews of user access listings), we inspected management's procedures to assess the validity of the CPI source and the completeness, accuracy, and integrity of the data or reports.